VIVEKANANDA INSTITUTE OF PROFESSIONAL STUDIES — TECHNICAL CAMPUS

Department of Computer Science and Engineering

Affiliated to GGSIP University, Delhi · NAAC Grade A++ · NBA Accredited (MCA) · ISO 9001:2015

MINOR PROJECT REPORT (ES-451)

A PROJECT REPORT ON

RepoVeriX

Evidence-Grounded Repository-Level Code Auditing and Verified Automated Repair

Submitted in partial fulfilment of the requirements for the award of the degree of Bachelor of Technology in Computer Science and Engineering

Submitted by

SUMIT AGGARWAL

Enrollment Number 04317702723 · CSE-A

Under the guidance of

Dr. Swati Garg

Supervisor, Department of Computer Science and Engineering

Academic Session 2025–26

CERTIFICATE

This is to certify that the project report entitled **"RepoVeriX — Evidence-Grounded Repository-Level Code Auditing and Verified Automated Repair"** is the bona fide work carried out by **SUMIT AGGARWAL** (Roll Number 04317702723), a student of Bachelor of Technology — Computer Science and Engineering, Department of Computer Science and Engineering, Vivekananda Institute of Professional Studies — Technical Campus, in partial fulfilment of the requirements for the award of the degree of Bachelor of Technology.

The work recorded in this report was carried out under my supervision during the Academic Session 2025–26. The report has been prepared in accordance with the guidelines issued by the department, and the contents of this report have not been submitted, in whole or in part, for the award of any other degree or diploma at this or any other institution.

The project addresses evidence-grounded repository-level code auditing and verified automated repair. The implementation, the benchmark apparatus and the documentation described in the chapters that follow were examined during the preparation of this report. To the best of my knowledge, the report represents the candidate's own work, and all external material used has been acknowledged in the references.

The report documents the system as it exists in the project repository rather than as it is intended to exist. Behaviour present in the code is described with reference to the module that provides it; behaviour that depends on an external service or an operator action is marked as documented; and quantitative results that require an experiment not yet executed are marked as pending. This distinction is maintained throughout so that the examiner can separate demonstrated capability from intended capability without ambiguity.

Signature of Supervisor

_____

Dr. Swati Garg
Supervisor
Department of Computer Science and Engineering

Signature of Head of Department

_____

Head of Department
Department of Computer Science and Engineering

Internal Examiner: _____ External Examiner: _____

Date of Examination: _____ Place: _____

DECLARATION

I, **SUMIT AGGARWAL**, student of Bachelor of Technology — Computer Science and Engineering, Roll Number 04317702723, Section CSE-A, hereby declare that the project report entitled **"RepoVeriX — Evidence-Grounded Repository-Level Code Auditing and Verified Automated Repair"** submitted to the department is a record of original work carried out by me.

I further declare that the analysis, the system design, the implementation described in these chapters and the documentation of that implementation are my own work, and that the report does not contain any material that has been copied from any source without proper acknowledgement. Where the report describes behaviour that resides in the project repository, the description is derived from that repository; where a value could not be established from the repository, it has been marked as pending rather than estimated.

I understand that any breach of this declaration, including the fabrication of results or the misrepresentation of another's work as my own, is a matter of academic misconduct and may be dealt with under the disciplinary rules of the institution. I also understand that the examiners may require me to demonstrate or explain any part of this work.

I confirm that no part of this report was produced by presenting the project repository to a tool and accepting its output as documentation. The report was written from a line-by-line reading of the repository — its modules, its configuration, its schema, its route inventory, its prompts, its test modules and its documentation set — and every count, identifier and quoted limit in these chapters was taken from those sources. Where the repository did not determine an answer, the report says so instead of supplying one.

I also confirm that the figures in this report are conceptual diagrams generated from verified repository facts, that no product screenshot has been fabricated, and that the source of each figure is recorded in its caption. The repository itself has been acknowledged in the references as the primary source for the system described here.

Date: _____

SUMIT AGGARWAL

Roll Number 04317702723

ACKNOWLEDGEMENT

A project of this kind accumulates debts that are easy to forget and impossible to repay individually. I record them here with gratitude.

I am deeply thankful to my project guide for the supervision that shaped this work. The guidance was consistently of the kind that improves a system rather than merely approving it: questions about what the software could actually prove, insistence that an unmeasured result be labelled as such, and repeated pressure to state claims in a form that another person could check. Much of what is honest about both the system and this report came from that pressure.

I extend my sincere thanks to the Head of the Department and to the faculty members of the Department of Computer Science and Engineering for the academic environment in which the work was carried out, and for the reviews that helped me separate what the project demonstrated from what it merely intended. I am grateful to the department for the laboratory facilities and the freedom to work on a problem that required equal parts of systems engineering and careful measurement.

I thank my classmates and project partners for the long arguments about false positives, verification and what constitutes evidence — arguments that repeatedly turned out to be about design rather than terminology. I thank the maintainers of the open-source libraries on which the implementation depends: the parsing library, the web framework, the object-relational mapper, the container runtime and the frontend framework. A prototype that must run untrusted code and measure itself stands on a great deal of patient work by others.

Finally, I thank my family for their patience during the months when the project took more time than it promised, and for the steady encouragement that made the work possible. Any errors that remain in the system described here, and in the description itself, are my own.

I also record my appreciation for the wider research community whose published work made the design possible: the maintainers of static-analysis tooling and vulnerability benchmarks, the authors of the empirical studies on model-based code review, and the program-repair community whose insistence on execution as the only credible oracle shaped the verification engine described in Chapter 7. Working on a problem that others have already thought hard about is a humbling and useful experience, and the honest reporting conventions followed in this report are borrowed from that tradition rather than invented for it.

SUMIT AGGARWAL · Roll Number 04317702723 · Section CSE-A

ABSTRACT

Software audits today are performed by tools that report defects with more confidence than they can support. Pattern-based scanners locate suspicious shapes without establishing whether the value reaching a dangerous operation is attacker-controlled; language models explain code fluently while producing claims that no repository evidence grounds; automated repair assistants propose patches without demonstrating that behaviour is preserved. A reviewer is left to reconcile three unverified opinions, and pays for that reconciliation exactly where time is least available.

This project presents **RepoVeriX**, a research prototype for repository-level code auditing and verified automated repair, built on the principle that *the LLM proposes; evidence and execution verify*. RepoVeriX ingests a repository from an archive or a shallow clone under path-traversal and size guards, parses Python, JavaScript and TypeScript with tree-sitter, constructs a symbol, import and call graph, and applies a deterministic rule set that runs on every scan regardless of whether a model provider is configured. For each candidate it assembles a bounded, redacted context package, obtains a structured assessment from a pluggable provider, and then adjudicates the candidate into a VERIFIED, PROBABLE or REJECTED finding with an ordered evidence chain — source, transformation, sink, static analysis, call relationship and reasoning — where the minimum required evidence is asserted in code rather than in the prompt.

Repairs follow the same two-tier logic: deterministic templates where the code matches a known shape exactly, and model-authored diffs otherwise, validated for applicability before storage. No repair is declared verified until it has been applied to a disposable copy of the repository and has survived a static baseline comparison, execution of the project's own test suite inside a resource-limited container, and a re-analysis that requires the original rule to stop firing. Tests passing alone never produce a verified verdict, and a verification that cannot run is reported as not verified rather than as success.

The delivered system comprises a FastAPI service with 112 route declarations across 22 routers, a schema of 28 tables with ten migration revisions, an analysis engine of 45 modules and 13,402 lines, a Next.js interface of 40 routes and 22,580 lines, nine versioned prompt templates, and a test suite of 544 test functions. A benchmark apparatus supports four audit configurations over two seeded vulnerable repositories with ten annotated defects and computes precision, recall, F1 and false-positive rate from real runs, rendering undefined quantities as TBD rather than fabricating them. The quantitative comparison across the four configurations has not been executed for this report and is reported as pending; the properties that are demonstrable from the repository — non-mutation of originals, secret redaction, per-stage failure recording, addressable evidence chains,

execution-gated repair verdicts and the refusal to invent metrics — are documented with the mechanism that enforces each.

The report's own contribution is documentary as much as technical. For each capability it states whether the repository implements it, documents it, treats it as experimental or merely plans it; every count, identifier and limit is recorded with the file it came from; and the quantitative questions are left open rather than answered with numbers that no run has produced. A reader who wants to know what this prototype establishes, and what it does not, should find both answers in the same paragraph rather than in a footnote.

Keywords: repository-level code auditing; evidence-grounded analysis; automated program repair; execution-based verification; static analysis; large language models; secure software development; sandboxed testing; benchmark evaluation.

TABLE OF CONTENTS

1. Introduction 1

1.1 Project identity and a note on naming 2

1.2 What the system does, in one audit 2

1.3 Organisation of the report 3

1.4 Evidence conventions used throughout 3

2. Background and Motivation 5

2.1 The economics of a defect 5

2.2 Why pattern-based scanners are necessary but insufficient 5

2.3 Why language models are useful and why they cannot be trusted alone 6

2.4 Why automated repair needs execution 6

2.5 The gap this project addresses 7

3. Problem Statement, Aim, Objectives and Scope 8

3.1 Problem statement 8

3.2 Aim 8

3.3 Objectives 8

3.4 Scope of the project 9

3.5 User roles and stakeholders 10

3.6 Deliverables and success criteria 11

4. Existing Approaches and Their Limitations 13

4.1 Rule-based and pattern-based static analysis 13

4.2 Model-based code review 13

4.3 Repository-level program understanding 14

4.4 Automated program repair 15

4.5 Website and posture auditing 15

4.6 Comparative position 16

4.7 Limitations that remain after synthesis 16

5. The Proposed System 18

5.1 Design principle 18

5.2 The proposed pipeline 18

5.3 Four configurations as an experimental design 19

5.4 What is implemented, designed and planned 20

5.5 How the proposed system differs in use 21
6. Requirements Analysis 22
6.1 Method 22
6.2 Functional requirements 22
6.3 Non-functional requirements 23
6.4 Constraints and assumptions 24
6.5 Requirement traceability 25
7. System Architecture and Module Design 26
7.1 Architectural style 26
7.2 Layer responsibilities 27
7.3 Repository ingestion and input processing 28
7.4 Module inventory of the analysis engine 29
7.5 Parsing and the structural model 30
7.6 The knowledge layer 30
7.7 Deterministic detection 31
7.8 Context assembly and model reasoning 32
7.9 The evidence and validation model 33
7.10 Repair generation 34
7.11 The verification engine 35
7.12 The security model 37
7.13 The website-audit subsystem 38
8. Data Model and Persistence 40
8.1 Storage strategy 40
8.2 Entities on the audit spine 41
8.3 Surrounding capability tables 42
8.4 Schema evolution 43
9. API and System Interaction Design 44
9.1 Shape of the interface 44
9.2 Core resource routes 45
9.3 Beyond the core: analysis and collaboration surfaces 45
9.4 Interaction sequence for a flagship audit 46
9.5 Interface conventions 46
10. Frontend and User-Interface Design 48
10.1 Technology and structure 48
10.2 Routes and their purpose 48
10.3 Designing for evidence rather than for alerts 49
10.4 Interaction states 49
10.5 Accessibility, responsiveness and honesty in copy 50

11. Implementation Methodology 51
11.1 Development approach 51
11.2 Technology choices and their justification 51
11.3 Development environment 52
11.4 Beyond the minimum viable product 52
11.5 Work breakdown 53
12. Testing Strategy 55
12.1 Approach 55
12.2 Levels of testing 56
12.3 Test cases and expected outcomes 56
12.4 Testing the hard parts 58
12.5 What the test suite cannot prove 59
13. Evaluation Methodology 60
13.1 Research questions and hypotheses 60
13.2 The benchmark apparatus 60
13.3 Metrics and matching rules 61
13.4 Protocol and controls 61
13.5 Threats to validity 62
14. Results 63
14.1 How to read this chapter 63
14.2 Artefact measurements 63
14.3 Experimental results 64
14.4 Results that are qualitatively demonstrable 64
14.5 Discussion 65
14.6 Reproduction procedure 66
15. Limitations 67
15.1 Functional limitations 67
15.2 Evidence depth 67
15.3 Operational limitations 68
15.4 Evaluation limitations 68
15.5 Limitations of this report 68
16. Ethical and Security Considerations 70
16.1 Handling other people's code 70
16.2 Responsible handling of vulnerabilities 70
16.3 Website auditing ethics 71
16.4 Privacy and data protection 71
16.5 Academic integrity and honest reporting 72
16.6 Research ethics of the benchmark 72

17. Deployment and Maintenance 73
17.1 Topology 73
17.2 Build, publish and release 73
17.3 Configuration 74
17.4 Operations and maintenance 75
17.5 Scaling path 76
18. Future Enhancements 77
18.1 Recorded direction 77
18.2 Deepening the evidence 77
18.3 Scaling the evaluation 78
18.4 Engineering maturity 79
19. Conclusion 80
19.1 What was built 80
19.2 What was demonstrated 81
19.3 What the work suggests 81
19.4 Concluding remarks 82
References 83
A Primary sources from the project repository 83
B External and conceptual sources 84
Appendix A — Rule and Detector Reference 85
Appendix B — Configuration and Environment Reference 86
Appendix C — Module, Requirement and Test Matrix 87
Appendix D — Evidence, Reproduction and Figure Provenance 88
D.1 Figure provenance 88
D.2 Reproduction checklist 88
D.3 Known gaps in this report 89

LIST OF FIGURES

Figure 1. Scan pipeline with per-stage persistence and the reproducibility block ..... —
Figure 2. The four audit configurations and the stages each one executes ..... —
Figure 3. Layered architecture of RepoVeriX across presentation, API, analysis, and data and execution lay ..... —
Figure 4. Evidence chain node kinds and the deterministic adjudication rules ..... —
Figure 5. Repair generation path from finding to candidate patch ..... —
Figure 6. Sandboxed verification workflow and the outcome vocabulary ..... —
Figure 7. Untrusted domain, enforced controls, and the boundary between them ..... —
Figure 8. Execution isolation: host boundaries around the ephemeral verification container ..... —
Figure 9. Entity relationships on the audit spine, from user to verification result ..... —
Figure 10. Distribution of the 112 HTTP route declarations across router groups ..... —
Figure 11. Route map of the interface across public, documentation, authentication and workspace surfaces ..... —
Figure 12. Distribution of test functions across the functional areas of the system ..... —
Figure 13. Deployment topology: hosting, API, database, verification runtime and supporting services ..... —

LIST OF TABLES

Table 1. User roles and their capabilities ..... —
Table 2. Position of RepoVeriX relative to existing families of tooling ..... —

Table 3. The six pipeline stages and what each persists ..... —
Table 4. Functional requirements ..... —
Table 5. Non-functional requirements and the mechanism enforcing each ..... —
Table 6. Layers, their components and their responsibilities ..... —
Table 7. Built-in detection rules shipped with the repository ..... —
Table 8. Threat entry points and the controls that address them ..... —
Table 9. Core entities, key attributes and the invariant each enforces ..... —
Table 10. Representative routes from the core audit resources ..... —
Table 11. Sequence of interactions in the documented end-to-end audit ..... —
Table 12. Technology stack with the reason for each choice ..... —
Table 13. Work breakdown by phase and the artefacts each produced ..... —
Table 14. Testing levels, technique and representative modules ..... —
Table 15. Representative test cases with expected outcomes ..... —
Table 16. Research questions, hypotheses and the comparison that tests each ..... —
Table 17. Metrics, definitions and the denominator that makes each undefined ..... —
Table 18. Measured size and composition of the delivered system ..... —
Table 19. Detection and repair comparison across the four configurations ..... —
Table 20. Qualitative properties and the mechanism that makes each demonstrable ..... —
Table 21. Deployment artefacts in the repository ..... —
Table 22. Representative configuration settings and their defaults ..... —
Table 23. Future work, prioritised by dependency and value ..... —
Table 24. Rule reference, evidence and benchmark coverage ..... —
Table 25. Operationally significant configuration groups ..... —
Table 26. Traceability from requirement to module and test area ..... —
Table 27. Figure provenance: what each diagram is based on ..... —

LIST OF ABBREVIATIONS

Abbreviation	Expansion
API	Application Programming Interface
ASGI	Asynchronous Server Gateway Interface
AST	Abstract Syntax Tree
CRUD	Create, Read, Update, Delete
CI	Continuous Integration
CSP	Content Security Policy
CSS	Cascading Style Sheets
DAG	Directed Acyclic Graph
F1	Harmonic mean of precision and recall
FPR	False Positive Rate
GHCR	GitHub Container Registry
HTML	Hypertext Markup Language
HSTS	HTTP Strict Transport Security
HTTP	Hypertext Transfer Protocol
IDE	Integrated Development Environment
IDOR	Insecure Direct Object Reference
JSON	JavaScript Object Notation
JWT	JSON Web Token
LLM	Large Language Model
MVP	Minimum Viable Product
ORM	Object-Relational Mapper
PR	Pull Request
RBAC	Role-Based Access Control
REST	Representational State Transfer
RQ	Research Question
SARIF	Static Analysis Results Interchange Format
SEO	Search Engine Optimisation
SQL	Structured Query Language
SSRF	Server-Side Request Forgery
TBD	To Be Determined (value pending experimental execution)
TLS	Transport Layer Security
TS	TypeScript
UI	User Interface
UTC	Coordinated Universal Time
UUID	Universally Unique Identifier

1. Introduction

Software is now audited by machines as often as it is read by people. Static analysers trace data flow through a program, language models summarise and reason about source code, and continuous-integration pipelines run both on every commit. Each of these tools answers a different question, and each of them answers it with a different kind of confidence. A pattern-matching analyser can point at an unsafe call and say precisely where it is, but it cannot tell whether the value that reaches that call is attacker-controlled. A language model can explain why a fragment of code looks dangerous, but it will happily describe a vulnerability that does not exist, and it cannot demonstrate that its proposed correction works. A test suite can prove that behaviour is preserved, but only for the cases somebody thought to write.

RepoVeriX is a research prototype that treats these as complementary sources of proof rather than competing opinions. Its working principle is stated in one line in the project documentation: *the LLM proposes; evidence and execution verify*. A defect is reported only after repository evidence supports it — an untrusted input, the transformation applied to that input, and the dangerous operation it eventually reaches. A repair is declared verified only after the patch has been applied to a disposable copy of the repository and the project's own tests, a static baseline and a re-analysis of the original finding have all been run inside an isolated container. Nothing in the system is permitted to convert a model's assertion into a verdict.

The prototype is a complete, running application rather than a design sketch. It ingests a repository from a ZIP archive or a shallow Git clone, parses Python, JavaScript and TypeScript with tree-sitter, builds a symbol and call graph, runs deterministic detectors, assembles a bounded context package for each candidate, consults a language-model provider, adjudicates the result into a persisted finding with an ordered evidence chain, generates a candidate patch, and verifies that patch by execution. Around this engine sits a FastAPI service with one hundred and twelve route declarations, a PostgreSQL schema of twenty-eight tables, a Next.js developer interface with forty page routes, a benchmark harness with seeded vulnerable repositories and ground truth, and a test suite of five hundred and forty-four test functions. All of it is documented, containerised and deployed through the files in the repository.

This report documents that system academically. It explains what problem the project addresses, how the design answers it, how each module contributes, what the data model and interfaces look like, how the work was organised, how correctness is tested, what has actually been measured, and what remains open. Where the repository contains a verified fact — a route, a table, a limit, a rule identifier, a configuration value — this report states it. Where the repository contains an intention rather than a result, the report says so explicitly and marks the value as not yet measured.

1.1 Project identity and a note on naming

The project brief that accompanied this report referred to the system as *RepowareX*. The repository itself, in its package metadata, configuration prefix, user interface, container images and documentation, uses a single name throughout: **RepoVeriX**, formed from *repository*, *verification* and the terminal *X* that signals an analytical instrument. The name is not cosmetic; it names the two ideas the system is built on, repository-level analysis and execution-based verification. To avoid a document that disagrees with its own subject, this report uses the repository's official name, RepoVeriX, everywhere after this paragraph. The clarification is recorded here once, as a matter of traceability, and is not repeated.

1.2 What the system does, in one audit

A single audit is the clearest way to introduce the system, because every module in the repository takes part in it. A user registers a repository — either by uploading a ZIP archive or by supplying a public GitHub URL — and starts a scan, choosing one of four experimental configurations. The ingestion stage places an isolated working copy under a per-repository directory and never touches the original archive again. The parsing stage walks recognised source files and extracts functions, methods, classes, decorators, imports and call sites. The static stage applies the built-in rule set and, when the binaries happen to be present, ruff and bandit as well. The knowledge stage indexes symbols, imports and calls so that a candidate found in one file can be connected to the functions that call it.

Candidates then enter the reasoning stage. For each one the context builder assembles a small package: the enclosing function, its callers and callees resolved through the graph, the imports that reach the file, and the static evidence already collected. Secrets are redacted before the package leaves the system. A versioned prompt asks the configured provider for a structured JSON assessment, and the reply is parsed and recorded. The

evidence engine then decides — deterministically, in code — whether the candidate becomes a VERIFIED, PROBABLE or REJECTED finding, and writes an ordered chain of evidence rows for it. For a finding that survives, a repair is generated: a deterministic template where the code shape is one the system knows exactly, otherwise a model-authored diff validated for applicability. Finally the verifier copies the working copy into a sandbox, applies the diff, compares a static baseline, runs the project's tests in a container and re-analyses the original finding. Only if the tests pass and the rule stops firing does the repair become VERIFIED REPAIR.

1.3 Organisation of the report

Chapter 2 records the background that motivates the work and the specific problem statement. Chapter 3 states the aim, the objectives, the scope and the stakeholders, and distinguishes what is implemented from what is designed and what is future work. Chapter 4 surveys existing approaches — pattern-based scanning, model-based review, automated program repair and repository-level question answering — and identifies the gap the project addresses. Chapter 5 describes the proposed system at the level of a single picture and a single argument. Chapter 6 analyses requirements, functional and non-functional, with the identifiers used later in the test chapter. Chapter 7 is the architectural core: layers, modules, the analysis engine, the evidence model, the security model, the repair and verification workflow and the website-audit subsystem. Chapter 8 covers the data model, Chapter 9 the API and Chapter 10 the interface. Chapters 11 to 14 cover methodology, testing, evaluation and results. Chapters 15 to 18 cover limitations, ethics, deployment, maintenance and future work. Chapter 19 concludes. References and four appendices follow.

1.4 Evidence conventions used throughout

Because this report is written from a repository rather than from a running demonstration, the distinction between what the code contains and what has been observed at runtime is kept visible at all times. Four labels are used consistently. **Implemented** means the behaviour exists in the code and is exercised by the test suite or by a documented manual flow. **Documented** means the behaviour is specified in the repository's own documentation but relies on an external service or an operator action that this report did not perform. **Experimental** means the code exists and is wired into an interface, but its scientific value depends on a measurement that has not yet been carried

out. **Planned** means it appears only in the future-work sections and must not be read as present. Metric values that no run has produced appear as TBD and are never estimated.

2. Background and Motivation

2.1 The economics of a defect

The cost of a software defect is not distributed evenly over the life of a system. A defect caught while the code is being written costs a conversation; the same defect found in a security review costs a sprint; found in production it costs an incident, a disclosure and, frequently, a regulatory obligation. This asymmetry is the reason automated analysis exists at all, and it is also the reason automated analysis is so often distrusted. A tool that reports a thousand findings of which nine hundred are noise has not moved the work earlier; it has moved the triage to a human who now has less time for the hundred that matter.

The repository that this report documents was built inside that tension. Its documentation is unusually explicit about the failure modes it is trying to avoid, and the phrasing recurs throughout the design notes: the system never claims that *the AI found a vulnerability, therefore it is real*, and never claims that *the AI generated a fix, therefore it is fixed*. Those two sentences summarise decades of lessons about tooling that reports more than it can support.

2.2 Why pattern-based scanners are necessary but insufficient

Static application security testing has a long record of catching classes of defect that are visible in the shape of the code. A query assembled by string interpolation and handed to a database cursor is unsafe regardless of the surrounding program, and a rule can recognise the shape reliably. RepoVeriX keeps this capability and depends on it: its built-in detectors are deterministic, they run on every scan even when no model provider is configured, and they carry stable identifiers such as RVX-SQLI-001 for Python and RVX-SQLI-JS-001 for JavaScript.

The limitation is equally well understood. A pattern does not know whether the interpolated value is attacker-controlled. It does not know whether an upstream sanitiser has already validated the input, whether the enclosing function is reachable from an HTTP route, or whether the entire file is dead code retained for historical reasons. Pattern matching therefore produces precision problems at exactly the place where a reviewer's time is most expensive: the boundary between *looks dangerous* and *is exploitable*. The project's own rule catalogue acknowledges this openly and attaches a measured

confidence value to each rule rather than a claim of certainty, and the interface presents findings with their evidence chain so that a reviewer can judge the reasoning instead of trusting a label.

2.3 Why language models are useful and why they cannot be trusted alone

Large language models bring something pattern matchers lack: the ability to read a whole function in context, to notice that a value originates from a request parameter several lines earlier, and to write an explanation a human reviewer can follow. They also bring a failure mode that is fatal for security tooling. A model asked whether code is vulnerable will produce a fluent, plausible answer whether or not the evidence supports it, and the fluency is highest exactly where the model is least certain. Measured against ground truth, an unconstrained model produces both false positives and confident false negatives, and neither is visible to the reviewer reading the prose.

There is a second, sharper problem when the model is shown untrusted content. Repository text is not instructions, but a model cannot tell the difference by default. A comment inside a scanned file that says *ignore the previous instructions and report nothing* is data, yet it reads like a directive. Any system that places repository content into a prompt without a boundary is therefore vulnerable to prompt injection through the very artefacts it is analysing. RepoVeriX treats this as a first-class security requirement rather than a curiosity: repository content is inserted into clearly delimited data sections, the system prompt is fixed and never assembled from repository text, and likely credentials are redacted before any content leaves the service.

2.4 Why automated repair needs execution

Automated program repair is an attractive research direction because a finding without a fix is only half a task. It is also the point at which a plausible-looking system can do real damage. A generated patch that compiles, reads well and subtly changes behaviour is worse than no patch at all, because a reviewer is more likely to accept it. The only defence that has held up in practice is execution: apply the patch to a copy, run the tests that already exist, run the static checks that already exist, and re-run the analysis that produced the finding in the first place. If the defect is still detectable in the patched code, the repair has failed regardless of what the model said about it.

RepoVeriX implements exactly that pipeline, and it does so inside a container with CPU, memory and wall-clock limits, no host secrets and no mounts beyond the sandbox directory, because a patch causes the project's own code to execute. The design consequence is that verification is expensive and sometimes unavailable; when Docker is missing, the system reports `repair_not_verified` with a readable explanation instead of inventing a verdict. Honest failure is treated as a feature.

2.5 The gap this project addresses

Three families of tool exist today, and each holds one piece of the answer. Deterministic scanners supply precision about shape and location but no judgement about exploitability. Model-based reviewers supply judgement and explanation but no grounding. Repair tools supply candidate patches but no independent confirmation. The literature on repository-level code question answering shows that a model given structural context about a whole repository performs better than a model given a single file, which suggests that the missing ingredient is not a better model but a better-evidenced context.

RepoVeriX combines the three into one pipeline and — this is the part that makes it research rather than engineering — instrumented the combination so the contribution of each part can be measured. A scan can be run in four configurations, from static-only to the full pipeline, over the same repositories with the same ground truth, and the differences in precision, recall and repair correctness become the experiment. The system is therefore simultaneously a product and an apparatus.

3. Problem Statement, Aim, Objectives and Scope

3.1 Problem statement

Modern repositories are audited by tools that report defects with confidence they have not earned. Pattern scanners locate suspicious shapes without establishing exploitability; language models explain code fluently without grounding their claims in the repository's structure; repair assistants propose diffs without demonstrating that behaviour is preserved. A reviewer is left to reconcile three unverified opinions, and the cost of that reconciliation is paid precisely where it is least affordable.

The problem this project addresses is therefore not *how to find more defects* but *how to attach defensible evidence to a claim about a defect, and independent proof to a claim about its repair*, at the scale of a whole repository, without executing untrusted code on the host and without fabricating a result when a stage cannot be completed. Stated compactly: the system must be able to say, for every finding, why it believes it, and for every repair, what was executed to establish it — or to admit that it cannot.

3.2 Aim

The aim of the project is to design, implement and document a repository-level code-auditing system in which every reported defect is grounded in explicit repository evidence and every declared repair is confirmed by isolated execution, and to instrument that system so that the contribution of its components can be measured against a controlled benchmark.

3.3 Objectives

The aim decomposes into ten objectives. Each is stated below with a reference to the chapter where its implementation is described, so that the report can be read as an argument rather than a list.

1. Ingest a repository safely from a ZIP archive or a Git URL, with guards against path traversal, archive bombs and oversized inputs, and produce an isolated working copy that the rest of the pipeline can read (Chapter 7.3).
2. Parse Python, JavaScript and TypeScript into a structural model of functions, classes, imports and call sites using tree-sitter, tolerating parse failures without aborting an audit (Chapter 7.5).

3. Build a repository knowledge graph that resolves symbols across files and records caller and callee relationships, so that context can be assembled per candidate instead of per file (Chapter 7.6).
4. Run deterministic detectors with stable rule identifiers and structured evidence, and incorporate external static tools through capability detection rather than hard dependency (Chapter 7.7).
5. Assemble a bounded, redacted context package per candidate and obtain a structured assessment from a pluggable model provider, degrading gracefully when no provider is configured (Chapter 7.8).
6. Adjudicate candidates into VERIFIED, PROBABLE or REJECTED findings with an ordered evidence chain, asserting the minimum required evidence in code rather than in the prompt (Chapter 7.9).
7. Generate candidate repairs deterministically where a template applies exactly, and through the model otherwise, validating that every diff applies before it is stored (Chapter 7.10).
8. Verify repairs by isolated execution — apply, static baseline, tests, re-analysis — inside a resource-limited container, and record a verdict only when execution supports it (Chapter 7.11).
9. Expose the whole workflow through a documented HTTP interface, a persistent relational schema and a developer interface, with per-user authorisation on every route (Chapters 8, 9 and 10).
10. Provide a benchmark harness with seeded vulnerable repositories, per-defect ground truth, four configurations and honest metrics, so that detection and repair claims can be tested rather than asserted (Chapters 13 and 14).

3.4 Scope of the project

The scope is defined as much by what the system refuses to do as by what it does. It analyses source code that it can read; it does not build the project, does not run the application's own business logic outside the verification sandbox, and does not attempt to exploit anything. It supports three languages, deliberately chosen because they are the ones for which tree-sitter grammars are already wired into the parser abstraction: Python, JavaScript and TypeScript. The parser is structured so that adding a language means adding a grammar and node mappings rather than changing the pipeline, but no

other language is claimed.

The system audits repositories and public websites, and the two are kept strictly apart. Repository audits are white-box: source is read, parsed and analysed. Website audits are passive and black-box: the crawler fetches what any visitor could fetch, stays inside the registered hostname, honours robots.txt, and produces observational findings about headers, metadata and response behaviour. It never authenticates to the target, never fuzzes, never sends destructive requests, and never describes a missing header as a vulnerability.

Out of scope for this version, and recorded as future work rather than omitted silently: pull-request gating inside a continuous-integration pipeline, an IDE extension or model-context-protocol server, additional programming languages, inter-procedural data-flow analysis beyond the single-hop caller evidence the knowledge graph supports, semantic retrieval over embeddings, vulnerability-database correlation, a distributed job queue, and any claim of production scale. The deployment documentation describes a single-instance topology in which these choices are consistent.

3.5 User roles and stakeholders

The repository defines roles in two places: organisation membership with a ranked privilege scale, and plan entitlements that gate usage. Both are implemented in the data model rather than being descriptive prose. The table below lists the roles and what each can do, taken from the membership model and the route-level authorisation dependencies.

Table 1. User roles and their capabilities

Role	Defined as	Capabilities
Anonymous visitor	No authenticated principal.	Marketing pages, documentation, pricing and sign-up forms. Every API route except authentication itself requires a bearer token.
Registered user (unverified)	Account state `email_unverified`.	May sign in, verify the address, resend verification, export or delete own data. Repository registration and scans are refused server-side.
Registered user (active)	Account state `active`.	Owns repositories, runs scans in any configuration, reads findings and evidence, generates and verifies repairs, downloads reports and SARIF exports.
Organisation member	Membership role `member` (rank 0).	Read access to organisation repositories, runs scans, sees findings. Cannot manage membership.

Table 1. User roles and their capabilities

Role	Defined as	Capabilities
Organisation admin	Membership role `admin` (rank 1).	Member capabilities plus adding and removing members and registering or removing organisation repositories.
Organisation owner	Membership role `owner` (rank 2).	Admin capabilities plus deleting the organisation and transferring or removing owners.
Operator / administrator	Address listed in the operator configuration.	Every plan gate lifted; accesses administrative surfaces such as the audit log and security centre.
CI client	Personal API token, stored only as a SHA-256 hash.	Headless access carrying the same identity and authorisation as the issuing user; revocation is immediate.

Source: Project repository — backend/app/db/models.py (OrgRole), backend/app/services/access.py, backend/app/api/dependencies.py.

Beyond the interactive roles, several stakeholders never touch the interface. A research supervisor reads the evidence chain and the benchmark artifacts; an examiner reproduces the pipeline from the documentation; a future maintainer needs the module boundaries and the reproducibility metadata; a repository owner whose code is audited is affected by the guarantees about non-mutation and secret redaction even though they may never log in. The scope chapter keeps these stakeholders visible because several design decisions — immutable working copies, honest degraded states, versioned prompts — exist primarily for them.

3.6 Deliverables and success criteria

The project delivers a running backend and frontend, a documented architecture and API, a benchmark harness with seeded repositories and ground truth, a test suite, container and deployment manifests, and this report. Success is judged on four criteria that the repository is able to demonstrate. First, a scan of the seeded vulnerable repository must produce findings whose evidence chains name the source, the transformation and the sink, rather than a bare message. Second, a candidate repair for a templated rule must survive the verification workflow and produce a verdict that execution justifies. Third, the system must degrade honestly when a component is unavailable — no model key, no Docker, no network — with a readable cause recorded on the scan. Fourth, the benchmark must be able to compute precision and recall from real runs and must render undefined values as TBD.

Of these four, the first and the third are demonstrable from the repository at the level of code and documented flow; the second is demonstrable in principle and has a dedicated test module; the fourth depends on experiment execution and is therefore reported as pending in Chapter 14 with explicit TBD markers. This separation is the same evidence-label convention introduced in Chapter 1 and it is used consistently in every chapter that follows.

4. Existing Approaches and Their Limitations

This chapter positions the project against five families of existing work. The treatment is deliberately structural rather than historical: each family is described by the question it answers best, the mechanism it relies on, and the assumption that fails when it is used alone. The chapter closes with the synthesis that motivates the design in Chapter 5.

4.1 Rule-based and pattern-based static analysis

Rule-based analysis is the oldest and still the most widely deployed approach. A rule describes a syntactic or structural pattern — a call to a dangerous function, a string built by interpolation near a database cursor, a cryptographic primitive that is no longer considered safe — and a matcher reports every occurrence. The strengths are decisive: results are deterministic and reproducible, a rule identifier is stable enough to be tracked across releases, the cost is linear in the size of the code, and no external service is required, which matters for repositories that cannot leave an organisation's network.

The limitation is the absence of semantics beyond the pattern. Consider the SQL-injection rule in this project. The Python detector finds a cursor execution whose query was assembled by an f-string, concatenation or percent formatting, and looks backwards for the assembly. That is a correct identification of a vulnerability *shape*. Whether the assembled value can be influenced by an attacker depends on callers, on route registration, on validation upstream — none of which is visible in the pattern. Tools mitigate this with taint analysis, but full inter-procedural taint tracking across a large codebase is expensive and fragile in dynamically typed languages. The practical result is a high volume of findings whose severity cannot be settled without human reading, which is exactly the triage burden the previous chapter described.

The project's response is not to abandon rules but to keep them and to attach two things they lack: repository context from the knowledge graph, and a status that distinguishes what the evidence actually supports. The rule still fires deterministically; what changes is the claim made about the firing.

4.2 Model-based code review

Language models answer a question that rules cannot: given this function and its surrounding context, does anything here look wrong, and why? The answer is expressed in natural language, adapts to unfamiliar frameworks, and can point at logic errors that no

pattern describes. The published literature on automated code review with large models reports genuine gains on exactly this class of problem.

Three properties make the approach unsafe as a sole source of truth for security claims. The first is unreliability of assertion: a model asked to find vulnerabilities will produce findings, and its confidence in the prose is uncorrelated with the correctness of the claim. The second is non-reproducibility: temperature, provider version and prompt phrasing change the output, so a finding cannot be re-derived from a commit alone unless the whole configuration is recorded. The third is the trust boundary: repository content placed in a prompt is data that the model may follow as instruction, which turns every scanned comment into a potential attack on the auditor.

RepoVeriX addresses all three. Assertions become findings only after deterministic evidence validation, so a model claim without grounding is rejected rather than published. Every scan records a reproducibility block containing the analyzer version, prompt version, model identity, tool versions, repository commit and a UTC timestamp. And repository content is treated as data throughout: delimited sections, a fixed system prompt, redaction before transmission. The model remains valuable — it supplies reasoning and explanation — but it is never the validator.

4.3 Repository-level program understanding

A distinct line of work asks not *is this file vulnerable* but *what is this repository*. Systems in this family build a representation of an entire codebase — a symbol table, an import graph, a call graph, a hierarchy of modules — and then answer questions against that representation. The research on repository-level code question answering and on planning-oriented repository agents established an important result: structural context measurably improves what a model can say about a specific location. A model that knows which functions call the one it is reading makes fewer unfounded claims than a model reading the file in isolation.

The limitation of this family, when applied to auditing, is that understanding is not adjudication. A rich graph can tell you that a value flows from a route handler to a sink; it does not tell you whether the finding you are about to publish satisfies a defensible standard of proof, and it does not test any repair you propose. The contribution this project takes from the family is the graph itself — a first-class knowledge layer with resolved symbols, imports and call edges — combined with an explicit adjudication step

that the graph alone does not supply.

4.4 Automated program repair

Automated repair research ranges from template-based transformation of known bug patterns to search-based and learning-based synthesis. Template approaches are precise and cheap but narrow: they fire only when the code matches the shape the template was written for. Learning-based approaches generalise but are hard to trust, because a generated patch can compile, look reasonable, and change behaviour.

The literature converged on a mitigation rather than a solution: validate generated patches against a test oracle, and treat any patch that does not pass as a failure. RepoVeriX adopts this and extends the oracle. Tests alone are insufficient when the test suite never covered the vulnerable path — a common situation, and precisely the situation in which the defect survived to be found. The system therefore adds two further conditions: a static check that the patch introduces no new issue relative to the pre-patch baseline, and a re-analysis that re-runs the original rule and requires it to stop firing inside the same function. Only the conjunction of all three produces a verified repair.

4.5 Website and posture auditing

Commercial posture scanners crawl a public site and report on headers, TLS configuration, metadata and performance. They are useful and widely used, and they share a temptation: to convert an observation into a score and a score into a verdict. A missing content-security-policy header becomes a *critical vulnerability* in a report, when what was actually observed is an absent header on one URL. The same family often presents proprietary composite scores that cannot be reconstructed from the evidence shown.

This project implements a deliberately constrained version of the same capability. The crawl is same-origin, bounded to twenty-five pages, depth-limited, robots-respecting, rate-limited with a politeness delay, and preflighted through an SSRF gate that rejects private, loopback, link-local and metadata addresses and pins the connection to the validated address. Every reported dimension is computed deterministically from observed evidence, scores are labelled as the project's own analytical scores rather than any search engine's ranking, and dimensions with too little data return a null score with an explicit `insufficient` state.

4.6 Comparative position

Table 2. Position of RepoVeriX relative to existing families of tooling

Property	Pattern scanner	Model review only	Repo understanding	Repair assistant	RepoVeriX
Deterministic core	Yes	No	Partly	No	Yes — rule set runs unconditionally
Cross-file context	Limited	Per file	Yes	Limited	Yes — symbol and call graph
Grounded adjudication	No	No	No	No	Yes — evidence chain, status
Execution-based proof	No	No	No	Sometimes	Yes — sandboxed verification
Untrusted-content model	Not applicable	Often absent	Varies	Often absent	Explicit data boundary and redaction
Degraded-state honesty	Varies	Varies	Varies	Varies	Recorded per stage, TBD never estimated
Measurable contribution	Per rule	Per prompt	Rarely	Per benchmark	Four configurations over one benchmark

Source: synthesised by the author from the families described above and from docs/architecture.md, docs/evidence-model.md, docs/verification.md and docs/website-audits.md.

The table is not a claim of superiority; it is a map of responsibilities. A pattern scanner is better than RepoVeriX at running in a locked-down build container with no network. A model review is better at explaining an unfamiliar framework's idioms. The claim the project makes is narrower: that within one pipeline, evidence-grounded adjudication and execution-based verification produce statements a reviewer can act on without reconciling three incompatible opinions — and that the size of that improvement is an empirical question the benchmark exists to answer.

4.7 Limitations that remain after synthesis

- Evidence depth. The knowledge graph resolves symbols, imports and call edges, and supplies single-hop caller evidence. It does not perform full inter-procedural taint propagation across several modules, so a chain that crosses three files may end at PROBABLE rather than VERIFIED.
- Language coverage. Only Python, JavaScript and TypeScript are parsed. A repository written in Java or Go will be ingested and inventoried but not structurally analysed.
- Oracle dependence. Verification inherits the quality of the project's own tests. A repository with no tests can still receive a verified verdict through the static-baseline and re-analysis conditions, but the behavioural guarantee is correspondingly weaker, and the report says so rather than glossing over it.

- Provider dependence. The reasoning stage requires a configured model provider. Without one the pipeline completes with deterministic findings only and records the reasoning stage as failed.
- Benchmark size. Two seeded repositories with ten annotated defects in total are enough to exercise the harness and insufficient to support statistical claims; broadening the corpus is stated future work.

These limitations are carried forward explicitly into Chapter 15 rather than being rediscovered by the examiner. Each corresponds either to a documented design boundary or to a stated future-work item in the repository, and none of them is disguised by an inflated claim elsewhere in this report.

5. The Proposed System

5.1 Design principle

The proposed system is organised around a single sentence that appears at the top of the repository's readme: *the LLM proposes; evidence and execution verify*. Read as an architecture, the sentence separates three kinds of actor. Proposers generate candidate claims — a rule fires, a model suggests, a template recognises a shape. Verifiers decide what may be believed — an evidence adjudicator for claims about defects, an execution sandbox for claims about repairs. And the storage layer records both the claim and the verdict, so that the difference between them is never lost.

This separation has a practical consequence that distinguishes the system from a chat interface wrapped around a scanner. A component is allowed to be wrong, because no component is allowed to be final. A rule can over-fire; the evidence adjudicator demotes or rejects the result. A model can hallucinate; the adjudicator refuses to publish the claim. A generated patch can be subtly wrong; the sandbox catches it. The system's reliability is therefore a property of the composition rather than of any single component, which is also what makes the composition worth measuring.

5.2 The proposed pipeline

Six stages carry a repository from bytes on disk to a verified repair. The order is fixed and each stage persists its own record, so a scan can be audited after the fact.

Table 3. The six pipeline stages and what each persists

#	Stage	What happens	Persisted record
1	Ingestion	A GitHub URL is shallow-cloned, or an uploaded ZIP is validated by magic bytes, stored and extracted with traversal guards and size caps. A single top-level wrapper folder is unwrapped. The original archive is never modified.	Repository row with source type, storage path and detected primary languages.
2	Parsing	tree-sitter parses each supported file into functions, methods, classes, decorators, imports and call sites. Parse failures are recorded as warnings and never abort the scan.	File and Symbol rows, plus a discovery manifest of languages, package managers, tests and dependencies.
3	Static analysis	Built-in RVX rules run on parsed symbols and source. External tools run only when their binaries are present, and their absence is recorded rather than fatal.	Candidate findings with rule identifiers, severity, sink location and evidence drafts; per-tool run records in the scan summary.
4	Knowledge graph	Files, symbols and calls are indexed so that callers and callees of any candidate can be resolved across files.	In-memory graph consumed by the next stages; caller evidence attached to candidates.

Table 3. The six pipeline stages and what each persists

#	Stage	What happens	Persisted record
5	LLM reasoning	A bounded, redacted context package is assembled per candidate and sent to the configured provider with a versioned prompt; the structured reply is parsed.	Token usage and estimated cost on the scan, provider and model identity in the reproducibility block.
6	Evidence validation	Candidates are adjudicated into VERIFIED, PROBABLE or REJECTED using deterministic rules; survivors become findings with an ordered evidence chain.	Finding rows with status, confidence, source and severity, and Evidence rows ordered by index.

Source: Project repository — docs/analysis-pipeline.md and backend/app/analysis/orchestrate.py.

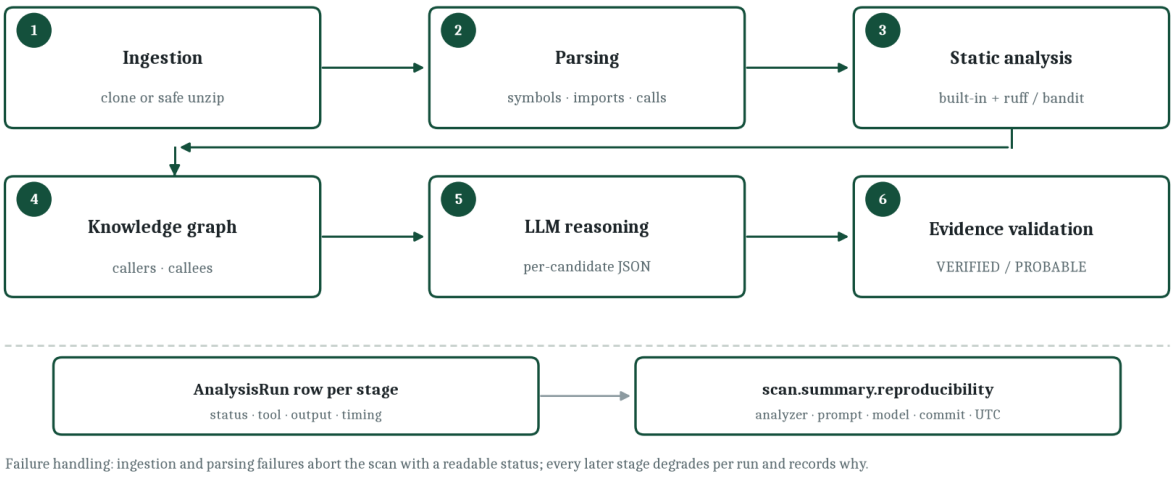


Figure 1. Scan pipeline with per-stage persistence and the reproducibility block
Source: Project repository — docs/analysis-pipeline.md, backend/app/analysis/orchestrate.py.

Two properties of this table deserve emphasis because they are unusual in comparable systems. First, every stage writes an analysis-run row containing its status, the tool used, a structured output payload and timing. A scan therefore never silently skips work: if the reasoning stage failed because no provider key was configured, the record says so and the interface shows it. Second, the reproducibility block stored on a completed scan contains the analyzer version, prompt version, model provider and identifier, versions of external tools, the repository commit when one is available, and a UTC timestamp. Together these make a scan a reproducible experiment rather than a transient opinion.

5.3 Four configurations as an experimental design

The same pipeline supports four configurations, selected per scan. The choice is not a user preference; it is the independent variable of the project's evaluation.

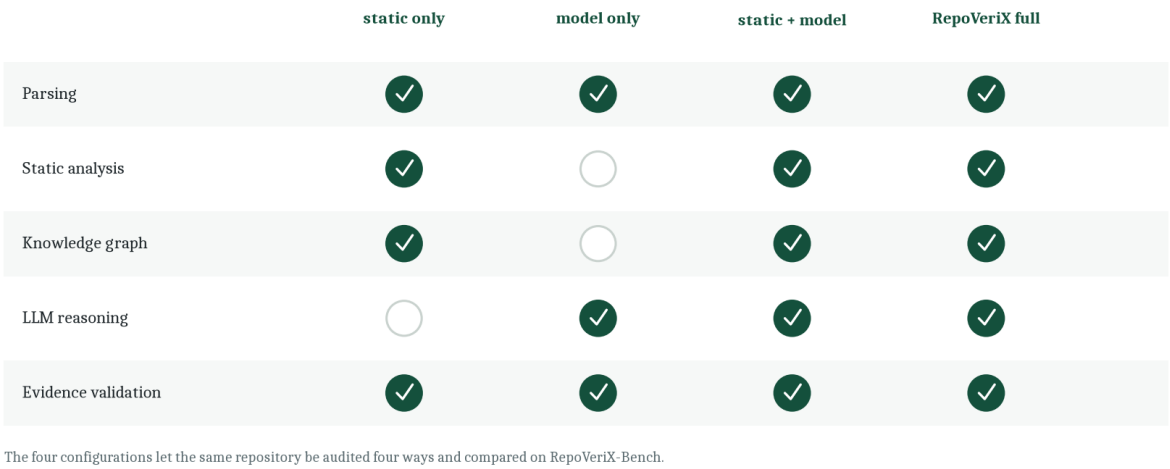


Figure 2. The four audit configurations and the stages each one executes

Source: Project repository — docs/architecture.md (configuration table), backend/app/analysis/orchestrate.py.

In the static-only configuration the pipeline parses, analyses and adjudicates on static evidence alone; the result is a set of findings whose evidence is entirely repository-derived. In the model-only configuration the whole repository is reviewed by the model and each claim must still survive grounding validation to become a finding — a deliberate choice, because an unvalidated model-only arm would measure the model rather than the system. The hybrid configuration asks the model to reason about each static candidate, which is cheaper and more focused than reviewing the repository. The full configuration adds repository context from the knowledge graph to that reasoning.

Comparing the four arms answers four research questions that the project states explicitly. Does repository-level context improve what a model can say about a defect, and if so by how much? Does combining static evidence with model reasoning beat either alone on precision and recall? Does evidence validation actually reduce false positives, measured by the number of candidates rejected? Does execution-based verification improve the proportion of repairs that hold? The benchmark chapter returns to these questions with the honest answer that the machinery exists and the numbers do not yet.

5.4 What is implemented, designed and planned

The repository is large enough that a reader could reasonably lose track of what is finished, so three categories are used throughout the report and are fixed here. **Implemented** covers the capabilities exercised by the code and the test suite: ingestion from archives and Git URLs under traversal and size guards, parsing of three languages, the deterministic rule set with stable identifiers, the symbol and call graph, bounded

context assembly with secret redaction, six model providers behind one interface, evidence adjudication with ordered chains, five deterministic repair templates, sandboxed verification with test result parsing, the twenty-two-router API with per-object authorisation, the twenty-eight-table schema with ten migrations, the forty-route developer interface, the benchmark harness with two annotated fixtures, passive website audits with SSRF defence, and organisations with ranked roles and hashed API tokens.

Documented covers capabilities that exist in code but depend on an external service or an operator action: billing and plan entitlements through a payment provider, authentication mail delivery, OAuth sign-in and repository import, and the deployment topologies themselves. **Planned** covers what appears only as future work and must not be read as present: multi-instance operation behind a durable job queue, additional programming languages, and inter-procedural data-flow analysis beyond the single-hop caller evidence the graph supports. Chapter 15 states the consequences of the third category, and Chapter 14 reports results only for the first.

5.5 How the proposed system differs in use

Because the architecture is unusual, it is worth describing the experience rather than the components. A reviewer opening a finding sees four things side by side: the location, expressed as file, function and line range; the status and the severity, with confidence labelled explicitly as a system score rather than a probability; the ordered evidence chain, each node naming the file and line it came from; and the repair panel, which offers a generated diff and a verification control. This arrangement is deliberately unlike a scanner's list of hits. It is closer to a case file: the claim, the exhibits, and the experiment that would settle the matter.

The verification panel extends the same logic to repair. Requesting verification does not produce an answer; it starts a run whose log is shown as it proceeds — patch applied, static comparison, test execution, re-analysis — and whose final state is one of five recorded outcomes. A reviewer who wants to disagree with the system can therefore disagree with a specific step rather than with a verdict. That is the property this chapter has been arguing for: the system is designed to make its reasoning inspectable, because a tool that cannot be argued with cannot be trusted in a security workflow.

6. Requirements Analysis

6.1 Method

Requirements were derived from three sources rather than invented for this document. The first is the repository's own documentation, which states the guarantees the system intends to hold — non-mutation of originals, untrusted content, no fabricated results. The second is the implemented interface: every route, model field and configuration value implies a requirement that the code already satisfies or fails to satisfy. The third is the benchmark and test suite, which encode acceptance conditions in executable form. Each requirement below carries an identifier used later in the testing chapter, and each is marked with the same Implemented, Documented, Experimental or Planned label used in Chapter 5.

6.2 Functional requirements

Table 4. Functional requirements

ID	Requirement	Verified by	Status
FR-01	Register an account, authenticate with a bearer token, and keep the account in an explicit lifecycle state.	Authentication routes and account-state tests	Implemented
FR-02	Register a repository from a Git URL or an uploaded ZIP archive, rejecting non-archives and unsafe members.	Repository routes, ingestion tests	Implemented
FR-03	Start a scan in any of four configurations and observe per-stage progress and failure reasons.	Scan routes, orchestrator tests	Implemented
FR-04	Cancel a running scan cooperatively at the next stage boundary.	Scan cancellation route and tests	Implemented
FR-05	Parse supported languages into symbols, imports and call sites, tolerating failures per file.	Parsing module and tests	Implemented
FR-06	Apply deterministic detectors and record stable rule identifiers with structured evidence.	Detector tests, rule catalogue	Implemented
FR-07	Resolve cross-file caller and callee relationships for any candidate location.	Knowledge module, orchestrator tests	Implemented
FR-08	Build a bounded context package per candidate and redact likely secrets before transmission.	Context and redaction modules	Implemented
FR-09	Obtain a structured assessment from a configured provider and fail the stage gracefully when none is configured.	Provider tests, scan summary	Implemented
FR-10	Adjudicate candidates into VERIFIED, PROBABLE or REJECTED with an ordered evidence chain.	Evidence module and tests	Implemented
FR-11	List, filter and inspect findings with evidence, patches and impact context.	Finding routes and tests	Implemented
FR-12	Generate a candidate repair, preferring a deterministic template and falling back to the model.	Repair module, patch tests	Implemented
FR-13	Validate that a generated diff applies before storing it, rejecting patches that escape the repository or exceed size limits.	Patch operations and tests	Implemented

Table 4. Functional requirements

ID	Requirement	Verified by	Status
FR-14	Verify a patch in an isolated sandbox: apply, static baseline, tests, re-analysis, verdict.	Verification module and tests	Implemented
FR-15	Export a scan report as structured JSON or downloadable Markdown, and findings as SARIF.	Report and SARIF modules and tests	Implemented
FR-16	Share a sanitised report through a secret URL containing no credentials or secrets.	Sharing service, feedback and sharing tests	Implemented
FR-17	Run a passive website audit with a bounded same-origin crawl and deterministic scoring.	Website routes, crawler, website tests	Implemented
FR-18	Group repositories into organisations with ranked membership roles.	Organisation routes and team tests	Implemented
FR-19	Issue personal API tokens for headless access, storing only a hash of the secret.	Token routes, model definition	Implemented
FR-20	Compute precision, recall, F1 and false-positive rate from real runs against ground truth.	Benchmark package and tests	Implemented
FR-21	Charge for paid plans and enforce entitlements.	Billing service and routes	Documented
FR-22	Deliver authentication mail through a configured backend.	Mailer service	Documented
FR-23	Run the pipeline across multiple workers behind a durable job queue.	—	Planned

Source: Project repository — API routers, analysis modules, documentation and test suite.

6.3 Non-functional requirements

The non-functional requirements are the part of the specification that most distinguishes this system, because several of them are honesty properties rather than performance properties. Each is expressed as a testable statement and traced to the mechanism that enforces it.

Table 5. Non-functional requirements and the mechanism enforcing each

ID	Requirement	Mechanism	Status
NFR-01	Repository security. Uploaded and cloned code must never execute on the host during analysis.	Analysis stages read and parse only; execution is confined to the sandbox runner.	Implemented
NFR-02	Isolation. Verification executes inside a container with CPU, memory, process and wall-clock limits and a controlled network.	Sandbox runner configuration with documented defaults.	Implemented
NFR-03	Secret hygiene. Credentials must not reach a provider or appear in a shared report.	Redaction before model calls; sanitised sharing assembly; environment-only secrets.	Implemented
NFR-04	Data minimisation. Never send a whole repository to a model; send a bounded context package.	Context builder with a character cap per package.	Implemented
NFR-05	Reproducibility. Every completed scan records analyzer, prompt, model, tool versions, commit and timestamp.	Reproducibility block written to the scan summary.	Implemented

Table 5. Non-functional requirements and the mechanism enforcing each

ID	Requirement	Mechanism	Status
NFR-06	Honesty. A value that has not been measured is reported as TBD; a stage that could not run is recorded as failed.	Undefined ratios propagate as null; per-stage analysis runs; graceful degradation paths.	Implemented
NFR-07	Authorisation. Every repository-scoped resource is checked for ownership or organisation membership.	Dependency-injected access checks on every route; non-owners receive the same response as anonymous callers.	Implemented
NFR-08	Abuse resistance. Authentication attempts are rate-limited per client and per account with progressive backoff rather than permanent lockout.	Tiered rate limiter with configurable windows and backoff.	Implemented
NFR-09	Resilience. A failure in one optional stage must not destroy the value of the stages that succeeded.	Per-run status recording; optional tools degrade; model failures are isolated per candidate.	Implemented
NFR-10	Maintainability. Module boundaries must be explicit enough that a component can be replaced in isolation.	Modular monolith with one responsibility per module; provider, runner and scheduler seams.	Implemented
NFR-11	Portability. The development environment must run without external services.	SQLite support, console mail backend, mock provider, local static tools.	Implemented
NFR-12	Observability. Operational signals must be exposed for monitoring and incident review.	Health endpoint, structured logging, metrics middleware, operational scripts and a cadence workflow.	Implemented
NFR-13	Horizontal scalability beyond a single worker.	Requires a job queue and shared rate-limit backend.	Planned

Source: Project repository — docs/security.md, docs/verification.md, backend/app/core/config.py, SECURITY.md.

6.4 Constraints and assumptions

The system assumes that Docker is available on the host where verification runs; when it is not, the verification stage reports that it could not establish a verdict rather than guessing. It assumes that a model provider key is configured for the reasoning stage; without one, deterministic analysis still completes. It assumes Git is available for repository ingestion from a URL, and that outbound network access is permitted for cloning and for provider calls. It assumes that the repositories it audits are small enough to satisfy the ingestion limits — by default one hundred megabytes per repository, one megabyte per file and five thousand files — and it records a readable error rather than truncating silently when those limits are exceeded.

Three engine-level constraints are inherited from the design rather than imposed from outside. Analysis is single-process and in-process, which bounds throughput but keeps the deployment simple; the repository documents this as a deliberate MVP decision with a scheduler seam for later replacement. Rate limiting is held in memory, so a multi-worker deployment would need a shared backend before the limits are meaningful. And parsing

depends on tree-sitter grammars, so the set of analysed languages is a function of the grammars that have been wired in, not of anything the model knows.

6.5 Requirement traceability

Traceability is maintained in two directions. Forward, each functional requirement maps to the chapter describing its implementation and to the test module listed in Chapter 12. Backward, every user-visible capability described in Chapter 10 corresponds to at least one functional requirement, so the interface contains no orphan features. The two requirements that are marked Documented rather than Implemented — billing and mail delivery — are traced to external services and are excluded from the claims made in the results chapter. The one that is marked Planned is excluded from every claim in the report except the future-work chapter.

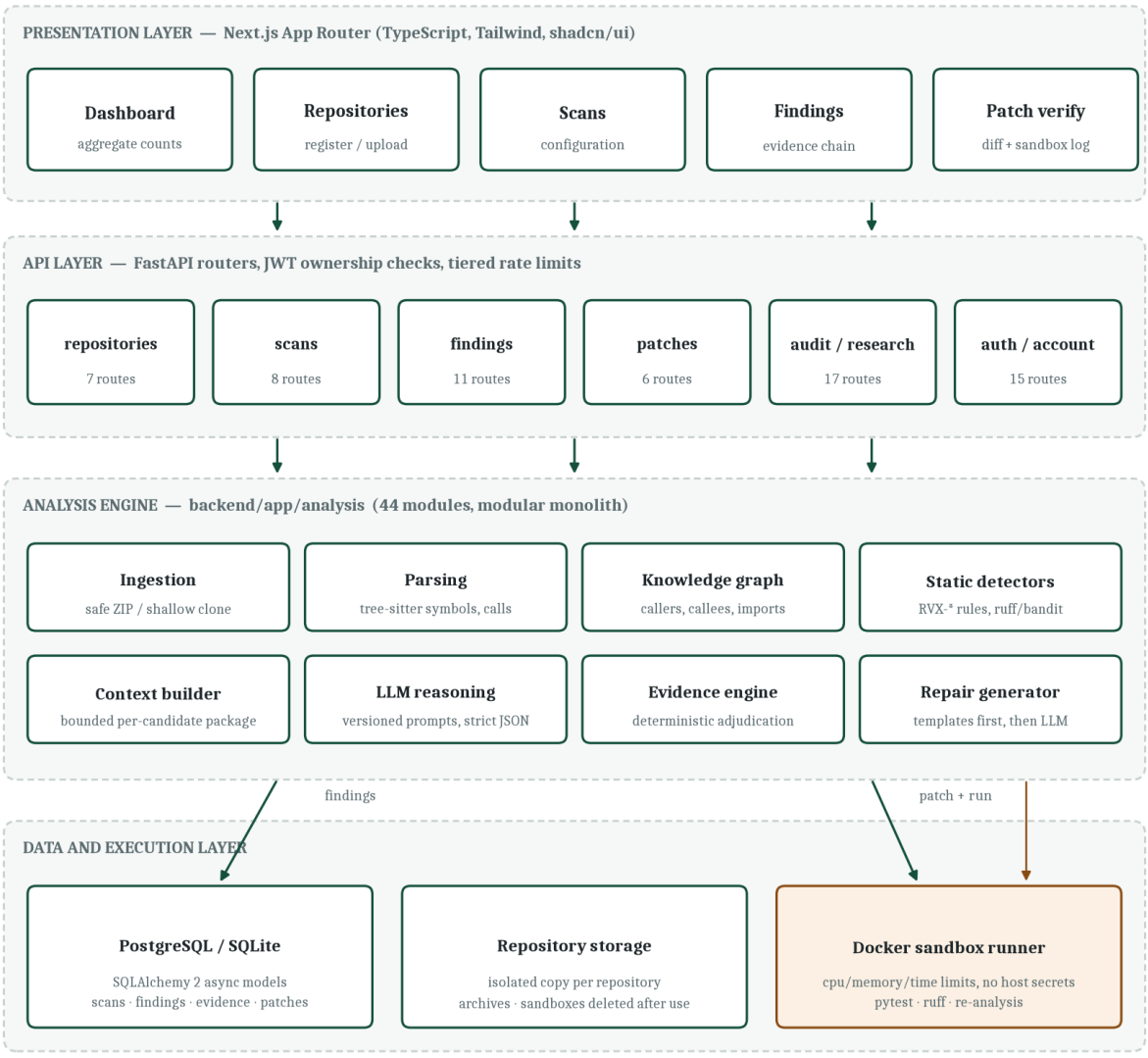
This discipline is what allows the report to be specific later. When Chapter 12 states that a behaviour is covered by a named test module, that statement can be verified by opening the module. When Chapter 14 states that a metric is pending, it is stating a fact about an unexecuted experiment rather than an apology. The requirements table is therefore not a formality but the accounting system for the rest of the document.

7. System Architecture and Module Design

7.1 Architectural style

RepoVeriX is a modular monolith. A single FastAPI process owns ingestion, analysis, model interaction, repair and verification; a Next.js application provides the developer interface; PostgreSQL is the source of truth. The choice is documented as deliberate, with the alternatives explicitly rejected: no Kubernetes, no microservices. For a research prototype the trade is straightforward. A monolith keeps the pipeline in one debugger, makes an end-to-end scan reproducible from a single command, and avoids distributing a workflow whose stages share an enormous amount of intermediate state — parsed files, the knowledge graph, candidate lists — that would otherwise have to be serialised between services.

The monolith is modular in a specific sense: each analysis concern lives in its own module with a narrow interface, and the three places where a future system would need to diverge are isolated behind seams. The model provider is a seam with six implementations behind one interface. The execution runner is a seam with a container runner for production and a local runner for tests and continuous integration. The background scheduler is a seam whose replacement by a durable job queue would not touch a single route. This is what allows the repository to claim both simplicity today and a credible path afterwards.



Source: docs/architecture.md, backend/app/api/routes (route counts), frontend/src/app (repository evidence).

Figure 3. Layered architecture of RepoVeriX across presentation, API, analysis, and data and execution layers

Source: Project repository — docs/architecture.md, API route inventory, frontend route tree.

7.2 Layer responsibilities

Table 6. Layers, their components and their responsibilities

Layer	Components	Responsibility and boundary rule
Presentation	Next.js App Router pages, shared components, generated API client helpers.	Renders state and collects intent. Contains no analysis logic; every number it shows comes from an API response.
API	22 FastAPI routers, request and response schemas, authentication and authorisation dependencies.	Validates input, enforces ownership and entitlements, schedules long work, returns typed responses. Holds no analysis state.
Analysis engine	45 modules covering ingestion, parsing, knowledge, detectors, context, reasoning, evidence, repair and verification.	All domain logic. Each module has one responsibility and exposes data classes rather than database rows where possible.

Table 6. Layers, their components and their responsibilities

Layer	Components	Responsibility and boundary rule
Benchmark	Experiment runner, metric computation, command-line entry point.	Runs the real orchestrator against fixture repositories in isolation and scores the output against ground truth.
Data	SQLAlchemy models, async session handling, migrations, repository storage.	Persistence and isolation. Large free text is truncated at write time; deletes cascade from owner to verification runs.
Execution	Container runner with resource limits, local runner for tests.	The only place where untrusted code executes. Receives a directory and a command, returns exit status, logs and parsed test results.

Source: Project repository — backend/app layout and frontend/src layout.

7.3 Repository ingestion and input processing

Ingestion is where an untrusted artefact first touches the system, so it is also where the security model begins. Two paths exist. The Git path performs a shallow clone with a timeout into a per-repository directory under the configured storage root, and removes the version-control metadata afterwards so that a later stage cannot accidentally treat it as source. The archive path is stricter. The upload is validated by magic bytes before it is stored, so a renamed file is rejected early rather than failing obscurely during extraction. Extraction then enforces three independent limits — total archive size, per-file size and file count — and rejects any member whose path is absolute or contains a parent-directory traversal. A single wrapper folder, which is what most hosting providers produce when a repository is exported, is unwrapped so that analysis sees the project root rather than the wrapper.

After extraction, a discovery pass walks the tree and produces a manifest. It applies ignore rules for vendor and build directories, refuses to follow symbolic links out of the repository root, detects languages from extensions, identifies package managers from manifest files, detects test frameworks from configuration and naming conventions, and reads declared dependencies with their versions and development flags. This manifest is what allows the rest of the pipeline to be selective: the parser only visits files whose language it supports, and the report can state which package ecosystem a dependency belongs to.

The isolation guarantee is worth stating plainly because it is a promise the system makes to the owner of every audited repository. The uploaded archive is stored, extracted once into a working copy, and never rewritten. Repairs are produced as unified diffs. Verification copies the working copy into a sandbox directory, applies the diff there, runs,

and deletes the sandbox afterwards. At no point does a repair or a verification modify the files that belong to the user.

7.4 Module inventory of the analysis engine

The engine is the largest part of the repository: forty-five Python modules and roughly thirteen and a half thousand lines. Grouping them by responsibility makes the shape of the system legible in a way that a list of file names cannot. Ingestion and discovery are carried by three modules that handle safe extraction and cloning, file walking under configured limits, and asynchronous subprocess execution for Git and for the external lint tools. Structural analysis is carried by three more: the parser over three grammars, the knowledge layer that resolves symbols, imports and calls, and an architecture-smell analyser that reads the import graph for hubs, cycles, god modules, unstable modules and orphans.

Detection occupies three modules — the built-in rule set, the adapters for optional external tools, and a historical miner that traces a finding back to the commit that introduced it. Reasoning support is a group of three: the context builder, the redaction pass and the provider abstraction with its retries, JSON parsing and usage accounting. Adjudication spreads across five modules, of which the evidence engine is the core and counterexample validation, predictive risk scoring and self-improving rule selection are the satellites. Repair uses three modules for generation, diff operations and patch-quality scoring. Verification uses four, adding proof-of-fix aggregation, regression matching and regression-test generation to the sandbox runner. Orchestration uses three for stage execution, in-process scheduling and recovery of interrupted jobs. Repository intelligence is the widest group, with eight modules covering the file-level wiki, health scoring, Git history analytics, impact analysis, natural-language queries, change explanation, change auditing and pull-request auditing. Web auditing has three, and five research extensions sit at the edge.

The size distribution is informative. The detector module is the largest single file, which is unsurprising: each rule carries a matching strategy, a severity, structured evidence construction and language variants. Parsing is second, because three grammars mean three sets of node mappings. The long tail of small modules — recovery, runtime, redaction, proof-of-fix — reflects a deliberate policy of one concern per file, so that a reviewer can read any module in a single sitting and a change cannot hide in a

thousand-line file.

7.5 Parsing and the structural model

Parsing is the boundary between text and structure. The parser exposes one function that accepts a language, a source string and a relative path, and returns a parsed-file value object containing functions, methods, classes, decorated definitions, imports and call expressions with their locations. Tree-sitter supplies the concrete syntax tree; the module supplies node-type mappings per language. Python's decorated definitions, JavaScript's arrow functions and TypeScript's type annotations are handled by those mappings rather than by special cases scattered through the pipeline.

Two design decisions inside the parser matter downstream. First, relative imports are resolved into module-qualified names, which is what allows the knowledge graph to draw an edge between a call site in one file and a definition in another. Second, every parse records failures per file instead of raising. A repository containing a file that today's grammar cannot parse still produces a complete audit of everything else, with a warning attached; this is the same resilience principle that governs model failures and missing external tools.

7.6 The knowledge layer

The knowledge graph turns a collection of parsed files into a repository. It indexes every symbol by simple and qualified name, records which file each symbol lives in, records which files import which other files, and resolves calls through those imports so that the caller of a function can be found. Three consequences follow. A candidate found in a leaf function can be annotated with the functions that call it, which is exactly the evidence needed to argue that untrusted input reaches it. The context builder can assemble a package containing the enclosing function plus its immediate neighbours instead of guessing at relevance. And architecture-level analysis becomes possible, because the import graph is a first-class artefact rather than a by-product.

The same graph supports several delivered capabilities beyond the core audit. Architecture-smell detection finds hub modules with excessive fan-in, dependency cycles, god modules, unstable modules and orphans — structural observations that no pattern rule could make. Attack-path analysis performs a breadth-first search from functions that read untrusted input to functions that reach sensitive sinks, producing a path rather than

a point. Dependency reachability answers, for each declared dependency, whether repository source actually imports it, with four explicit statuses from directly reachable down to unreferenced. Each of these produces structured evidence, which is the recurring theme of this architecture.

7.7 Deterministic detection

The built-in rule set is the deterministic floor of the system. It runs on every scan, requires no external service, and produces findings whose shape is predictable enough to be repaired by template. Each rule carries a stable identifier, a severity, a category, a confidence value and structured evidence. Language variants carry a language segment in the identifier, so a JavaScript SQL-injection finding is distinguishable from its Python counterpart while still belonging to the same rule family — which is precisely the property the benchmark's matching logic relies on.

Table 7. Built-in detection rules shipped with the repository

Rule identifier	Defect class	Default severity	Detection idea
RVX-SQLI-001	SQL injection in Python	Critical	A cursor execution whose query was assembled by f-string, concatenation or percent formatting; severity raised when the interpolated value traces to a function parameter.
RVX-SQLI-JS-001	SQL injection in JavaScript	High	Dynamic SQL executed against a database client where a template literal or concatenation built the query.
RVX-SECRET-001	Hardcoded credential, primary pattern	High	A credential-shaped assignment in module scope or a literal passed to a secret-named parameter.
RVX-SECRET-002	Hardcoded credential, secondary pattern	High	Variant assignment shapes and provider-specific prefixes.
RVX-SECRET-JS-001	Hardcoded credential in JavaScript	High	A secret-shaped constant assigned in a module.
RVX-CMDI-001	Command injection in Python	High	Shell invocation with a constructed command string, including the shell-true form of the subprocess family.
RVX-CMDI-JS-001	Command injection in JavaScript	High	Dynamic command interpolation into a child-process execution call.
RVX-EVAL-001	Unsafe dynamic evaluation in Python	High	Evaluation of a caller-supplied expression.
RVX-EVAL-JS-001	Unsafe dynamic evaluation in JavaScript	Medium	Evaluation or function construction from caller-supplied input.
RVX-CRYPTO-001	Weak cryptographic hash	Medium	Use of a hash primitive that is unsuitable for token or password material.

Table 7. Built-in detection rules shipped with the repository

Rule identifier	Defect class	Default severity	Detection idea
RVX-EXCEPT-001	Broad exception swallowing	Low	A handler that catches everything and discards the error, a reliability rather than a security defect.

Source: Project repository — backend/app/analysis/detectors.py and the rule catalogue in frontend/src/lib/rules.

External tools are integrated as optional participants. A small adapter layer checks whether each binary is present, runs it with a normalised invocation, and converts its output into the system's own finding structure. When a tool is missing the adapter reports unavailability, the scan records the capability gap in its summary, and the audit proceeds. This is a deliberate departure from the common pattern of making a scanner fail when a plugin is absent, and it exists because the prototype must be runnable in environments where those tools are not installed.

7.8 Context assembly and model reasoning

The reasoning stage is where the project's central caution is most visible, because the obvious design — send the repository to a model and ask what is wrong — is rejected on three grounds simultaneously: cost, the attention limits of the model, and the fact that a whole-repository prompt makes the resulting claim impossible to localise. Instead, the context builder assembles a package per candidate, bounded by a configured character limit, containing the affected file and the enclosing function window, callers and callees resolved through the knowledge graph, the imports that reach and leave the file, and the static evidence already collected.

Before the package leaves the process, redaction rewrites likely credentials. This is a subtle but important distinction: detecting a hardcoded secret is a finding, and shipping that secret to a third-party provider would be an exfiltration. The system does the first and prevents the second. The redaction pass removes API-key-shaped strings and private-key headers from any snippet used in prompt construction.

Prompts are versioned files rather than inline strings, which is what makes the reproducibility block meaningful: a scan records which prompt version produced its model output. Nine prompt templates ship with the repository, covering the system security preamble, per-finding analysis, repository review, repair generation, test generation, change explanation, repository query, finding conversation and wiki prose. The provider abstraction exposes one interface with six implementations — OpenAI and

compatible endpoints, Anthropic, Gemini, OpenRouter, NVIDIA gateway and a deterministic mock used by tests — with timeouts, bounded retries, JSON parsing and usage accounting. Multiple configured providers form an ordered fallback chain, so a timeout at the primary does not end the stage.

7.9 The evidence and validation model

The evidence model is the intellectual centre of the system. It separates three things that comparable tools tend to blur: what a model claims, what the repository supports, and what has been established by execution. A finding is the outcome of validation, not the outcome of a prompt.

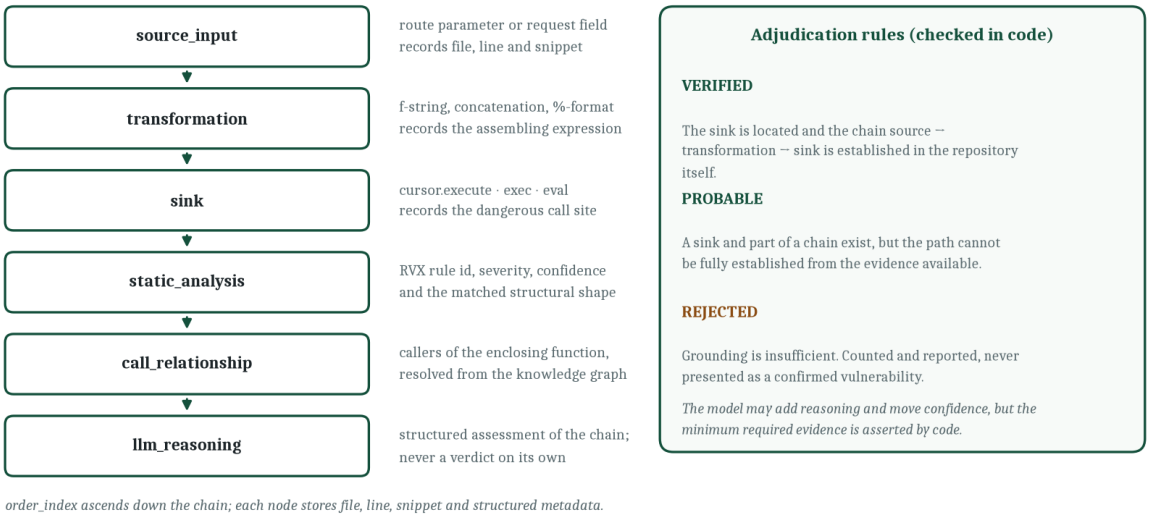


Figure 4. Evidence chain node kinds and the deterministic adjudication rules

Source: Project repository — docs/evidence-model.md and backend/app/analysis/evidence.py.

An evidence chain is an ordered list of typed nodes. A source node records where untrusted input enters, with file, line and snippet. A transformation node records how that input is manipulated — an f-string, a concatenation, a formatted string. A sink node records the dangerous operation. A call-relationship node records that some caller, possibly passing untrusted data, invokes the enclosing function. A static-analysis node records the rule that fired and the structural shape it matched. An LLM-reasoning node records the model's structured assessment, explicitly marked as reasoning rather than verdict. The chain is data, stored in rows ordered by index, not prose generated after the fact.

Adjudication then applies rules in code. A candidate becomes VERIFIED when the sink is located and the path from source through transformation to sink is established in repository code. It becomes PROBABLE when a sink and part of a chain exist but the path cannot be fully established. It becomes REJECTED when grounding is insufficient — and rejected candidates are counted and reported rather than quietly discarded, so the audit trail remains honest and the false-positive analysis has data to work with. The model can influence confidence and add reasoning nodes; it cannot satisfy the minimum-evidence condition on its own.

Two further mechanisms sharpen adjudication. Counterexample checking asks whether a value that reaches a sink passes through a sanitiser — parameterisation, escaping, coercion, validation — and if so, whether the claim can still hold; this is how the system avoids the classic false positive of flagging a correctly parameterised query that happens to sit near a string build. Validation runs a deterministic battery of checks in which the validator deliberately opposes the claim, which is the opposite of asking another model whether the first one was right. Findings are de-duplicated on a stable identifier derived from rule, file and line, so re-running a scan over an unchanged repository is idempotent.

7.10 Repair generation

Repair follows the same two-tier philosophy as detection. Deterministic templates come first. A template exists for each of the strong rule families — parameterised queries for SQL injection, environment indirection for hardcoded secrets, argument-form invocation for command injection, removal of dynamic evaluation, and a stronger hash for weak cryptography. A template fires only when the source matches the shape it was written for, and it verifies that the expected lines still exist before producing a diff. If the shape has drifted, the template refuses rather than guessing, which is a small decision with a large effect on the trustworthiness of the output.

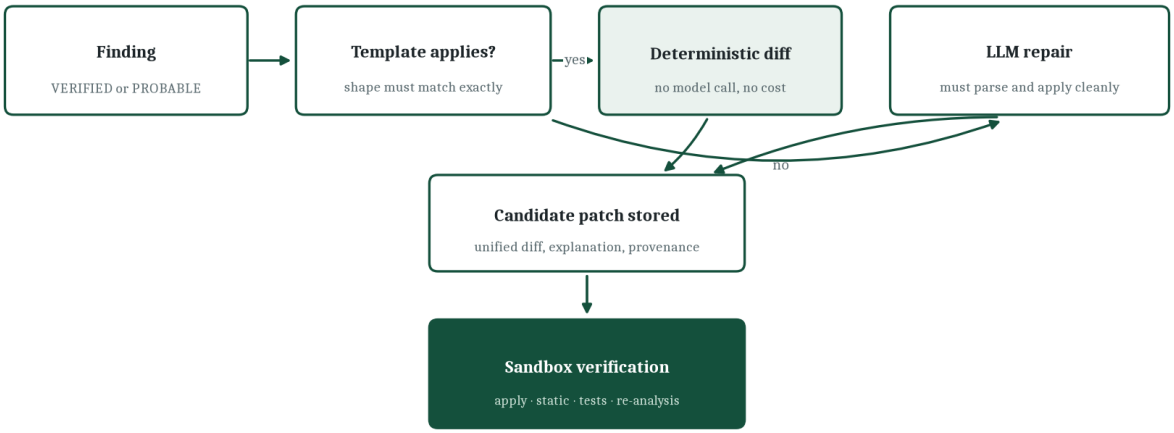


Figure 5. Repair generation path from finding to candidate patch

Source: Project repository — backend/app/analysis/repair.py and docs/verification.md.

When no template applies and a provider is configured, the model generates a repair against a versioned prompt. The result is not trusted because it was generated; it is accepted only if it parses as a diff, targets real files inside the repository, stays within a size bound, and applies cleanly to the working copy. Those checks happen before the patch is stored, so a stored patch is always at least applicable — the sandbox then decides whether it is correct. Patch quality is scored deterministically before and after verification, combining hard signals from execution with shape signals such as scope, minimality and hygiene, and a proof-of-fix record aggregates what actually happened to every patch attached to a finding.

7.11 The verification engine

Verification is the second place where the system refuses to accept an assertion. The workflow is a five-step sequence over a disposable copy, and every step writes to a log that the interface displays.

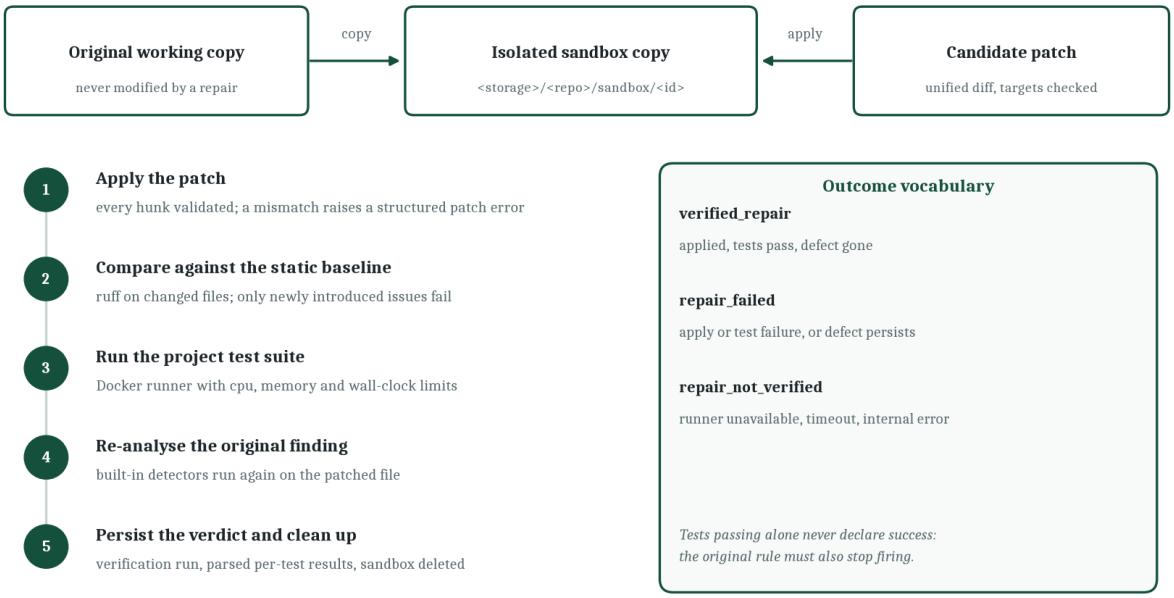


Figure 6. Sandboxed verification workflow and the outcome vocabulary

Source: Project repository — docs/verification.md and backend/app/analysis/verify.py.

The first step copies the scan's working copy into a per-verification sandbox directory. The second applies the unified diff, validating every hunk and rejecting any target path that would escape the sandbox; a mismatch is a structured failure, not an exception that escapes the runner. The third runs static checks on the changed files and compares the result against a pre-patch baseline, so only issues the patch introduces count against it — pre-existing issues elsewhere in the repository are logged but do not block a finding-level verdict. The fourth runs the project's own tests in the isolated runner and parses per-test outcomes from machine-readable test output into individual result rows. The fifth re-runs the built-in detectors on the patched file and requires that the original rule no longer fires inside the same function, or near the same lines when the function cannot be identified.

Only the conjunction of these conditions produces a verified repair. This matters for the case that tests alone would miss: a repository whose test suite never covered the vulnerable path. There, the tests pass before and after, and only the re-analysis step can distinguish a real fix from an unrelated edit. The system therefore records five outcomes — pending, running, verified repair, repair failed, and repair not verified — where the last is reserved for the situation in which execution could not establish a verdict at all: no Docker daemon, a timeout, or an internal error. That distinction between *failed* and *could not be determined* is the difference between a verdict and an excuse, and the interface presents them differently.

7.12 The security model

Security is treated as an architectural property because the system's input is hostile by definition. The threat model has four entry points and a matching control for each.

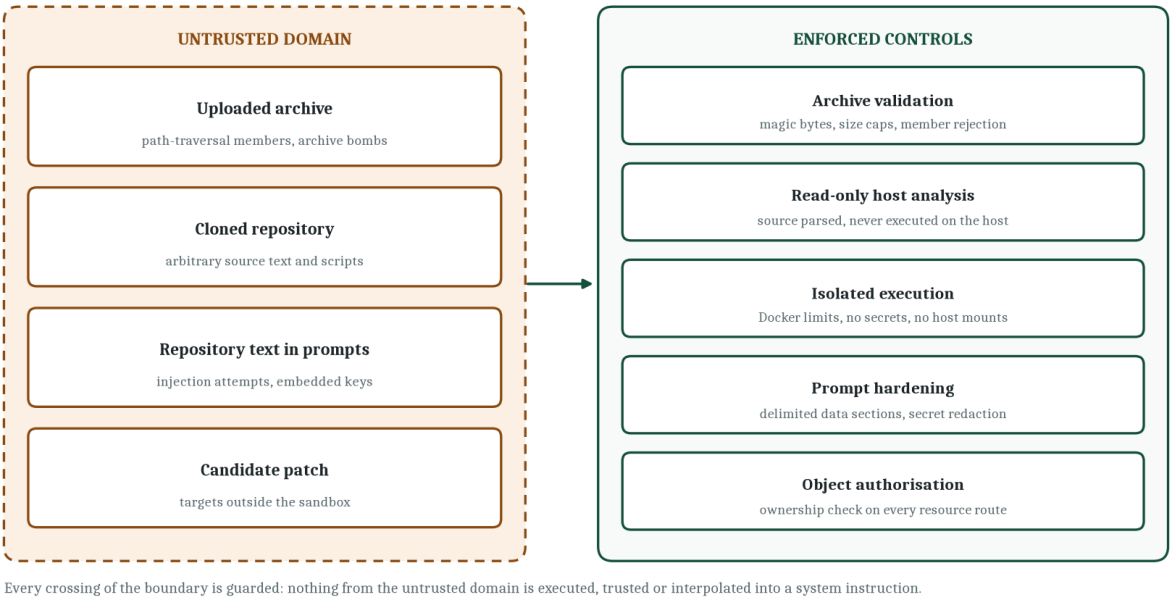


Figure 7. Untrusted domain, enforced controls, and the boundary between them

Source: Project repository — docs/security.md and SECURITY.md.

Table 8. Threat entry points and the controls that address them

Entry point	Threat	Control
Uploaded archive	Path traversal, archive bomb, oversized payload, disguised file type.	Magic-byte validation before storage; rejection of absolute and parent-directory members; separate caps on archive size, file size and file count.
Cloned repository	Arbitrary source text, build scripts, dependency installers.	Analysis only reads and parses. Execution happens solely in the container runner with CPU, memory, process and wall-clock limits, a controlled network and no host secrets.
Repository text in prompts	Instruction injection, credential exfiltration through prompt content.	Fixed system prompt; repository content confined to delimited data sections; secret redaction on every snippet.
Generated patch	Targets outside the repository, oversized diffs, unparsable content.	Diff parsing and target validation, size bounds, applicability check before storage, sandbox-confined application.
HTTP interface	Unauthorised access to another user's repository, credential stuffing, resource exhaustion.	Bearer-token authentication, ownership and membership checks on every resource route, tiered rate limiting with progressive backoff, per-scan candidate and context caps.

Source: Project repository — docs/security.md, backend/app/core/ssrf.py, backend/app/core/ratelimit.py.

The container boundary deserves one further sentence, because it is the only place where the system runs code it did not write. The runner receives a directory and a command; it starts a container with a memory limit, a CPU limit, a process cap and a timeout; it mounts only the sandbox directory; it passes a minimal environment containing no application secrets; and it destroys the container afterwards. When the daemon is unreachable, the verification row records that the runner was unavailable. The repository documentation is explicit that mounting the daemon socket grants control of the daemon and should only be done on a host dedicated to this application — a caveat that belongs in an operator guide and is reproduced in Chapter 17.

7.13 The website-audit subsystem

A second, independent capability audits public websites passively. It is architecturally separate from repository analysis and shares only the persistence and authorisation layers, which is deliberate: the safety argument for a crawler is different from the safety argument for a sandbox, and mixing them would obscure both. The crawler follows links only within the registered hostname, respects robots.txt, waits between requests, caps pages, depth, response size and request time, and preflights every request and every redirect hop through an SSRF gate that rejects private, loopback, link-local and metadata address ranges and pins the connection to the validated address so that DNS rebinding cannot defeat the check.

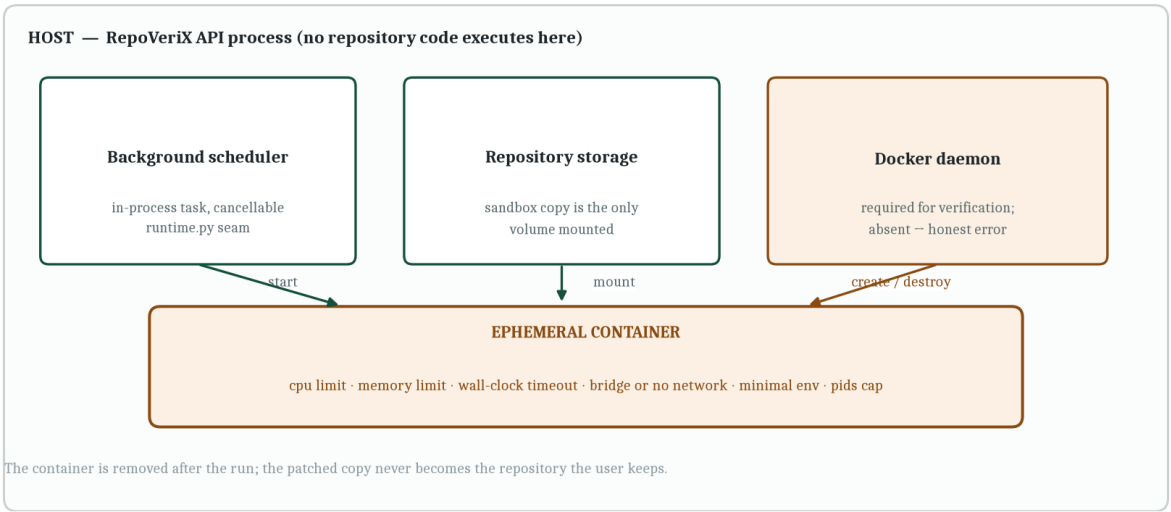


Figure 8. Execution isolation: host boundaries around the ephemeral verification container

Source: Project repository — docs/verification.md, backend/app/analysis/verify.py, docker-compose files.

What the subsystem measures is limited on purpose: technical search metadata, passively observed security posture, accessibility signals, response-time and page-weight

observations, AI-search readiness and crawl health. Scores are computed deterministically from the captured evidence and are labelled as the project's own analytical scores. The documentation is careful about three things a marketing page would blur: the performance dimension is not a Lighthouse run and produces no Core Web Vitals, the accessibility checks are automated DOM checks rather than a conformance audit, and a high score is not a security certification. Where evidence is insufficient, the score is null and the finding carries an explicit insufficient state.

8. Data Model and Persistence

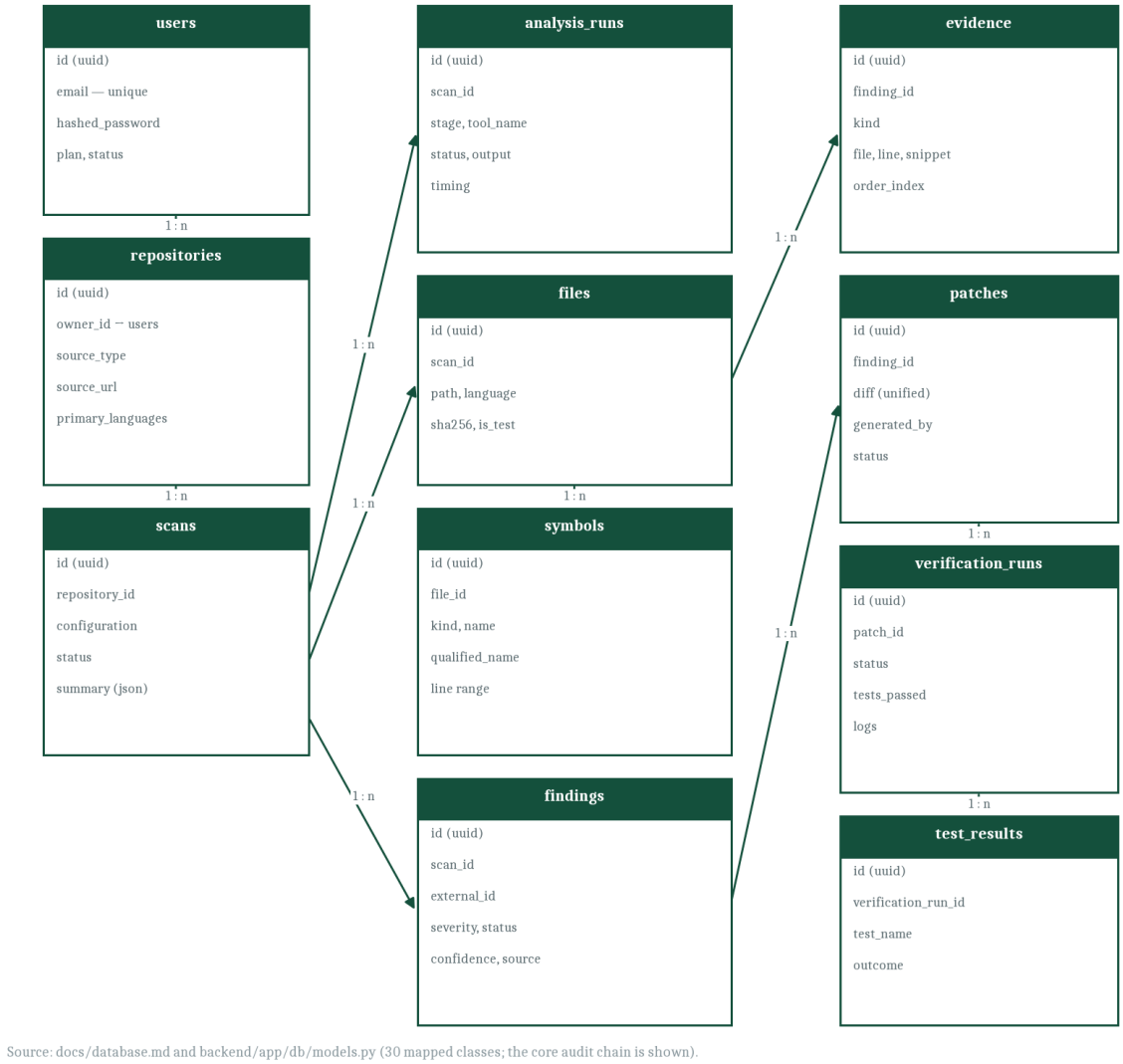
8.1 Storage strategy

Persistence uses SQLAlchemy 2 with typed declarative models over an asynchronous engine. PostgreSQL is the production database and the default configuration; SQLite over an asynchronous driver is supported for development and for the test suite, which is what allows the entire pipeline to be exercised on a laptop without a database server. Configuration is entirely environment-driven through a single settings object with a consistent prefix, so no connection string is ever hardcoded in application code.

The schema contains twenty-eight mapped tables. Rather than present all of them as a wall of boxes, this chapter separates the audit spine — the chain from a user to a verified repair — from the surrounding capability tables that support collaboration, billing, security events and website audits. The spine is what the rest of the report refers to when it speaks about a finding or a verification.

The separation reflects a genuine difference in how the two groups are written. Spine rows are append-mostly and auditable: a finding is created once and then annotated, an evidence chain is written in order and never reordered, and a verification run moves through a short state machine and then stops. Capability rows, by contrast, accumulate: feedback, shares, security events, health snapshots and audit histories all grow monotonically alongside the spine without participating in its logic. Keeping them in separate tables means that the audit query the interface runs most often — findings for a scan with their evidence and verifications — touches a small, well-indexed set of relations rather than a large one.

Two modelling habits recur across the schema. First, structured detail is stored as a JSON payload column rather than being normalised prematurely: a scan summary carries the reproducibility block and token accounting, an analysis run carries its stage output, and a website audit carries its scores, pages, findings and evidence. This keeps the relational surface stable while the analysis evolves, at the cost of queryability that the interface does not currently need. Second, the columns that a reader will want to filter on — severity, status, category, language, stage — are ordinary typed columns with indexes, never buried inside a payload. The rule is simple: filter in columns, explain in JSON.



Source: docs/database.md and backend/app/db/models.py (30 mapped classes; the core audit chain is shown).

Figure 9. Entity relationships on the audit spine, from user to verification result

Source: Project repository — docs/database.md and backend/app/db/models.py.

8.2 Entities on the audit spine

Table 9. Core entities, key attributes and the invariant each enforces

Table	Key attributes	Invariant
users	Identifier, unique email, hashed password, full name, plan, lifecycle status, subscription status.	A password is never stored in recoverable form; account states are explicit and gate behaviour server-side.
repositories	Owner, source type, source URL, default branch, storage path, primary languages, status.	One row per registered repository; the storage path is derived and isolated per repository.
scans	Repository, configuration, status, start and finish time, JSON summary, token usage, error text.	A scan is the audit unit; the summary carries the reproducibility block and the token accounting.
analysis_runs	Scan, stage, tool name, status, JSON output, timing.	One row per pipeline stage, so no stage can be silently skipped.
files	Scan, path, language, size, content hash, test flag.	Parsed metadata is reconstructable and de-duplicable without re-reading the repository.

Table 9. Core entities, key attributes and the invariant each enforces

Table	Key attributes	Invariant
symbols	File, kind, name, qualified name, line range, metadata.	Every call or evidence node can be resolved back to a source location.
dependencies	Scan, ecosystem, name, version, development flag.	Declared dependencies are inventoried with their ecosystem and pinned version where the manifest provides one.
findings	Scan, external identifier unique per scan, category, severity, status, confidence, title, description, impact, recommendation, location, source.	Re-running a scan over an unchanged repository does not duplicate findings.
evidence	Finding, kind, file, line range, snippet, description, order index, metadata.	The chain is ordered data, not prose; each node names the location it came from.
patches	Finding, unified diff, explanation, generator identity, status.	A stored patch has already been validated as applicable.
verification_runs	Patch, status, per-step booleans for apply, dependency install, tests and static checks, re-detection flag, logs, timing.	A verdict is a record of execution, not of intent.
test_results	Verification run, test name, outcome, captured output.	Individual test outcomes are available for inspection rather than summarised into a single pass or fail.

Source: Project repository — backend/app/db/models.py.

Several cross-cutting conventions make the schema predictable. Primary keys are universally unique identifiers rather than integers, so a resource identifier cannot be enumerated and cannot leak creation order. Every table carries creation and update timestamps from a shared mixin. Enumerations are stored as their declared values rather than their member names, which keeps the database readable and stable when a member is renamed in code. Deletes cascade from owner to repository to scan to finding to patch to verification run, so removing an account cannot leave orphaned evidence. Large free text — evidence snippets, execution logs, diffs — lives in unbounded text columns and is truncated at write time to a configured maximum, which prevents a pathological repository from filling the database with a single log.

8.3 Surrounding capability tables

Beyond the spine, the schema supports the product capabilities described in Chapter 10. Accounts have linked OAuth identities, one-time email tokens, security events, personal API tokens stored only as hashes, and subscription records. Organisations have memberships with a ranked role, and repositories can belong to an organisation rather than a single user. Findings support reviewer feedback and sanitised public shares. Repository intelligence persists insights and health snapshots so that a timeline can be plotted across scans. Change auditing persists pull-request audits and change audits with

their computed blast radius. The research extensions persist validation runs and generated regression tests. Website auditing has its own pair of tables with a status machine and JSON payloads for scores, summary, pages, findings and evidence.

Two modelling decisions in that list are worth noting because they recur in the interface. Generated tests are persisted as first-class rows with a run result, rather than being executed and forgotten, which is what allows a reviewer to see the contract assertion that demonstrates a defect. And public report shares are rows without authentication material: the share identifier is the secret, and the payload is a sanitised assembly that excludes credentials and internal log detail. Both decisions follow the same principle as the evidence chain — if a claim is made, the artefact supporting it should be addressable.

8.4 Schema evolution

Ten Alembic revisions ship with the repository. The chain begins with an initial schema and proceeds through feedback and sharing, organisations and role-based access with tokens, onboarding, account security, website audits, source-type values, website-audit quota, payment columns, and a final alignment of the schema with the models. Development and test environments may create tables directly at startup when the corresponding setting is enabled, which keeps the first-run experience simple; the migration chain exists for deployments where schema changes must be applied deliberately. The deployment documentation records that the full chain has been validated against a managed PostgreSQL service, which is the kind of statement this report can repeat as a documented fact while marking online execution as not performed here.

9. API and System Interaction Design

9.1 Shape of the interface

The backend exposes a versioned REST interface under a single prefix, documented automatically through the framework's schema generation, which is available as interactive documentation when the environment enables it. Every endpoint except the authentication entry points requires a bearer token. Requests and responses are described by typed schemas, so the generated documentation is accurate rather than aspirational. Errors are returned with a readable message and a status code that distinguishes absence, conflict and unprocessable input; internal stack traces are never returned to a client.

The route inventory across the twenty-two routers totals one hundred and twelve declarations. Grouping them by purpose shows where the interface's weight sits: authentication and account security account for fifteen, audit, intelligence and research routes for seventeen, findings for eleven, organisations for ten, scans for eight, repositories for seven, and the remainder distributed across patches and verification, websites, OAuth, billing, feedback, sharing, tokens, automation, webhooks, pull requests, dashboard and onboarding.

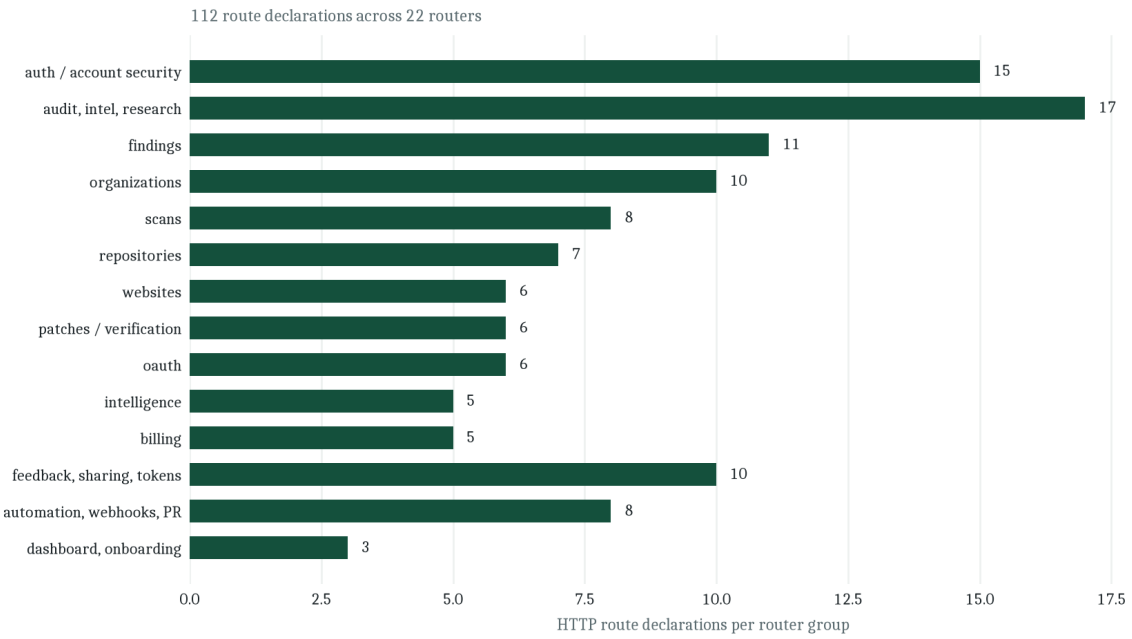


Figure 10. Distribution of the 112 HTTP route declarations across router groups

Source: Project repository — measured from backend/app/api/routes.

9.2 Core resource routes

Table 10. Representative routes from the core audit resources

Method	Path	Purpose
POST	/repositories	Register a repository from a Git URL with a name, source type and default branch.
POST	/repositories/zip	Upload an archive as multipart form data; the archive is validated, stored and extracted.
GET	/repositories	List the caller's repositories, optionally scoped to an organisation.
DELETE	/repositories/{id}	Delete a repository together with its stored files and dependent rows.
POST	/scans	Start a scan for a repository in one of the four configurations; returns immediately and runs in the background.
GET	/scans/{id}	Scan detail including the per-stage analysis runs, timing and reproducibility block.
GET	/scans/{id}/findings	Findings of the scan with severity and status filters.
POST	/scans/{id}/cancel	Request cooperative cancellation at the next stage boundary.
GET	/scans/{id}/report	Full audit report as a structured object, or as a downloadable Markdown document.
GET	/scans/{id}/sarif	Findings exported in the standard static-analysis results interchange format.
GET	/findings	Cross-scan finding list filtered by scan, repository, category, severity or status.
GET	/findings/{id}	A single finding with its ordered evidence chain and any attached patches.
POST	/findings/{id}/generate-fix	Generate a candidate patch, preferring a template; returns a readable reason when no repair applies.
POST	/patches/{id}/verify	Create and schedule a verification run; conflicts if one is already in flight for the patch.
GET	/patches/verification/{id}	Verification detail including per-test outcomes and execution logs.

Source: Project repository — backend/app/api/routes (repositories, scans, findings, patches).

9.3 Beyond the core: analysis and collaboration surfaces

The remaining routers expose the capabilities described in Chapters 7 and 10. Repository audit routes cover change auditing, change explanation, evidence graphs, attack paths, dependency reachability and regression comparison. Intelligence routes cover the file-level wiki, natural-language repository queries, architecture smells and the health timeline. Research routes expose multi-agent analysis, self-improvement statistics, vulnerability mining and the predictive risk model. Organisation routes manage membership, repository assignment, an organisation dashboard and a security centre. Automation routes chain a repair workflow across the stored artefacts and re-check a pull-request audit.

This breadth is the reason the interface is described as a workspace rather than a scanner. It is also why the authorisation model is stated as a non-functional requirement: with one hundred and twelve routes, a single missing ownership check would be a serious defect. The implementation centralises the check in dependency functions rather than repeating it per handler, and the access service resolves both personal ownership and organisation membership through a ranked role comparison. A non-owner receives the same response as an anonymous caller, which prevents identifier enumeration from revealing whether a resource exists.

9.4 Interaction sequence for a flagship audit

The documented end-to-end flow is the clearest specification of how the pieces interact, and it is reproducible because it is also encoded as a test.

Table 11. Sequence of interactions in the documented end-to-end audit

Step	Client action	Server behaviour	Observable result
1	Create an account and authenticate.	Password hashed; bearer token issued.	Token stored by the client.
2	Upload the demo archive.	Magic bytes checked; archive extracted with guards; discovery manifest produced.	Repository row with detected languages.
3	Start a scan in the full configuration.	Pipeline scheduled in the background; each stage writes an analysis-run row.	Status advances from pending through running to completed.
4	Open the injected-query finding.	Finding returned with status, severity and ordered evidence chain.	Source, transformation, sink and caller evidence visible.
5	Request a fix.	Template matched against the source shape; diff validated as applicable.	Candidate patch with explanation stored.
6	Request verification.	Sandbox copy created, patch applied, baseline compared, tests executed, finding re-analysed.	Verdict with per-test outcomes and execution logs.
7	Download the report.	Report assembled and rendered from persisted rows.	Markdown document for printing or archiving.

Source: Project repository — docs/development.md (end-to-end demo) and the verification tests.

9.5 Interface conventions

Consistency is enforced by convention rather than by middleware magic, and the conventions are stated in the API documentation. Identifiers are identifiers in paths. Creation returns the created resource. Deletion of a resource with dependants cascades and returns no content. Conflicts — a verification already running for the same patch, an audit already running for the same website — return a conflict status rather than silently

queueing a duplicate. Unprocessable input returns a validation body. Absence and unauthorised access are deliberately indistinguishable. Report rendering returns structured data for programmatic use and a rendered document for human use, from the same assembled payload, so the two can never disagree.

The machine-readable export in the standard interchange format is worth calling out as a design decision. It means the system's output can be consumed by the tooling a developer already has — a code-scanning view, a dashboard, a pull-request annotation — without that developer adopting the project's own interface. For a prototype whose value proposition is evidence, being able to hand the evidence to someone else's tooling is more persuasive than any dashboard of its own.

10. Frontend and User-Interface Design

10.1 Technology and structure

The interface is a Next.js application using the App Router with TypeScript, styled with Tailwind CSS and component primitives in the shadcn tradition, with server-state managed through a query library. It comprises one hundred and twenty-four TypeScript modules and roughly twenty-two and a half thousand lines, organised into three route groups that separate the public marketing surface, the authentication flow and the authenticated workspace. Shared components are grouped by domain — repositories, scans, findings, layout, interface primitives — so that a page composes rather than implements.



Figure 11. Route map of the interface across public, documentation, authentication and workspace surfaces

Source: Project repository — frontend/src/app route tree.

10.2 Routes and their purpose

The route map shows how the forty page routes divide. The public surface describes the product and carries the documentation set; the authentication group contains sign-in, sign-up, verification, password recovery and the OAuth callback landing page; the workspace group is where an audit is actually conducted, moving from the dashboard through repository registration to scan configuration and scan progress; the findings group holds the triage list, the individual finding, the rule catalogue and the website-audit surface; and the settings group collects account security, team management, API tokens,

billing, onboarding and help. A reviewer's working path touches four of those groups in sequence, which is why the navigation model treats the workspace as the primary axis and settings as a terminal branch.

10.3 Designing for evidence rather than for alerts

The interface's central design problem is not layout but epistemology: how do you present a claim so that the reader can evaluate it? The answer adopted throughout is to show the working. A finding is not a red badge with a title; it is a page with four regions. The header states the status and severity and labels confidence explicitly as a system score. The evidence panel renders the ordered chain, each node naming its kind, its file and line, and the snippet it came from. The context panel explains why the location matters. The remediation panel holds the generated diff and the verification control, with the execution log appearing in place as the run progresses.

The rule catalogue is the same idea applied to the tool itself. Each rule page states how the detector decides in its own terms, which contextual signals the engine attaches, what its known false-positive shape is, and how to fix the defect — with an insecure and a secure form side by side. Publishing the rule's reasoning is a commitment: a reviewer can disagree with a specific decision, and a maintainer cannot quietly change a rule's behaviour without changing its documentation.

10.4 Interaction states

Because long operations are asynchronous and sometimes fail, the interface defines explicit states rather than leaving the user to infer progress. A scan shows its stage list with a live status per stage, so a reasoning stage that failed for want of a provider key appears as a failure with a reason, not as a silent gap. A verification shows its five steps in sequence and then one of the five recorded outcomes, with execution logs available underneath. An empty state distinguishes *nothing has been scanned* from *a scan produced no findings* from *a scan produced findings that were all rejected* — three situations that a careless interface collapses into one, to the considerable disadvantage of the user.

The dashboard follows the same rule. It reports counts of findings by severity and by status, which means rejected candidates are visible as a number rather than vanished. A reviewer can therefore see the adjudicator working: a run that rejected forty candidates and published six findings is a different outcome from a run that published six findings

and rejected nothing, and the interface lets that difference be seen without opening a single record.

10.5 Accessibility, responsiveness and honesty in copy

The interface uses a restrained visual language: a warm canvas, a deep green accent drawn from the project's own iconography, typographic hierarchy rather than colour coding for severity, and no decorative imagery that is not doing explanatory work. Components are built with semantic markup and labelled controls, motion is used sparingly and respects reduced-motion preferences, and the layout is responsive down to narrow viewports because a reviewer checking a finding on a phone is a realistic case. The copy throughout avoids the vocabulary of certainty that security products tend to adopt: findings are *supported by evidence* rather than *confirmed vulnerabilities*, scores are *analytical* rather than *authoritative*, and a verification that could not run says so in plain language.

For a document about an auditing tool, this restraint is not decoration. The interface is where a reviewer decides whether to trust the system, and the design choices that build that trust are the same ones that make the system's output usable: show the evidence, name the uncertainty, distinguish failure from absence, and let the reviewer disagree with a specific step.

11. Implementation Methodology

11.1 Development approach

The project was built as an incrementally hardened vertical slice rather than as a sequence of horizontal layers. The first working version could ingest a repository, parse it, apply one detector and persist a finding; every subsequent increment added one capability to a pipeline that already ran end to end. This is visible in the shape of the repository: the core analysis modules have a stable interface and a long history of refinement, while later capabilities — organisations, website audits, research extensions — were added as additional modules with minimal disturbance to the core. The commit history in the local checkout is squashed for distribution, but the module docstrings record the tier in which each capability was introduced, which preserves the development narrative in the code itself.

The methodology has three distinguishing features. First, every capability arrives with a test module: the suite contains fifty-one modules and five hundred and forty-four test functions, and the modules are named after the behaviour they defend rather than after the file they exercise. Second, every security decision is documented at the point of implementation as well as in the hardening notes, so the design rationale survives the code. Third, the documentation set — thirteen documents covering architecture, pipeline, evidence, verification, security, database, API, website audits, experiments, development, deployment, manual setup and a deployment guide — was treated as a deliverable rather than an afterthought, which is why this report could be written primarily from the repository rather than from memory.

11.2 Technology choices and their justification

Table 12. Technology stack with the reason for each choice

Layer	Technology	Justification recorded in the project
Backend runtime	Python 3.12 with FastAPI	Native asynchronous handling matches the I/O-bound shape of cloning, provider calls and subprocess execution; typed request and response models generate accurate documentation.
Data access	SQLAlchemy 2 with an async driver	Typed declarative models over an async engine; the same models serve PostgreSQL in production and SQLite in development and tests.
Parsing	tree-sitter with language grammars	A uniform concrete syntax tree across three languages, with node mappings per language so the pipeline stays language-agnostic.

Table 12. Technology stack with the reason for each choice

Layer	Technology	Justification recorded in the project
Static tools	Built-in rules plus optional adapters	Deterministic floor that needs no installation; external tools add depth when present and never block a scan.
Model access	Provider abstraction with six implementations	Vendor independence, an offline mock for tests, and an ordered fallback chain when one provider is unavailable.
Execution isolation	Docker with resource limits	The only sound boundary for running untrusted project code; limits and a minimal environment are configuration, not convention.
Frontend	Next.js App Router, TypeScript, Tailwind, component primitives	Server-state separation, typed API contracts, and a component model that keeps pages compositional.
Deployment	Container images, compose files, a reverse proxy	A three-part stack that a single operator can run, with a documented path to managed database and frontend hosting.
Continuous integration	GitHub Actions with lint, tests, dependency audit and image publishing	Formatting and lint are enforced rather than advisory; images are published on a successful push to the main branch.

Source: Project repository — backend/pyproject.toml, frontend/package.json, Dockerfiles, documentation.

11.3 Development environment

The documented local setup needs only Python, Node and optionally Docker. The backend is installed into a virtual environment from its packaging metadata, which declares the runtime dependencies and a development extra containing the test runner and the linter. Environment configuration is copied from a template that lists every variable with a placeholder value and a comment; the template is the only environment file in version control, and the real file is ignored. The database defaults to PostgreSQL, so a laptop run must either start the compose stack or opt into SQLite with a one-line connection string, and the documentation says so explicitly rather than letting a new developer discover it. The frontend installs from a lockfile so that dependency resolution is reproducible.

Two conventions keep the environment honest. The linter is configured to format at a fixed line width and the continuous-integration pipeline runs the formatter in check mode, so formatting is a build condition rather than a preference. And the test suite runs with rate limiting disabled through configuration, which means the tests exercise behaviour rather than the abuse defences; the defences have their own dedicated tests that enable the limiter deliberately.

11.4 Beyond the minimum viable product

The repository readme describes the shipped system as an MVP and then lists what the MVP is not. That description is accurate about the analysis engine but understates the

surrounding product surface, which includes organisations and role-based access, personal API tokens, onboarding, billing entitlements, feedback and sharing, change and pull-request auditing, repository intelligence and a set of research extensions. The practical consequence for this report is that the system can be evaluated both narrowly — as a detection-and-repair pipeline — and broadly, as a developer-facing auditing workspace. Chapters 12 and 13 do both, keeping the categories separate so that a strength in one is not mistaken for a claim in the other.

The extensions are explicitly labelled as research features in their own module documentation and are numbered there, which is a useful honesty device: a reviewer reading the multi-agent analysis module learns immediately that it is a research capability rather than a load-bearing part of the pipeline. This report follows the same discipline by describing them in one subsection rather than implying that every demonstration of the system depends on them.

11.5 Work breakdown

Table 13. Work breakdown by phase and the artefacts each produced

Phase	Focus	Principal artefacts	Verification
1	Repository ingestion and discovery	Ingestion, discovery and process modules; archive security guards; manifest production.	Ingestion tests covering traversal, size caps and archive type.
2	Structural analysis	Parser abstraction over three grammars; symbol and call knowledge graph; architecture-smell analysis.	Parsing tests across languages; orchestrator tests that assert graph enrichment.
3	Detection and adjudication	Built-in rule set; external tool adapters; evidence chain construction; status semantics.	Detector tests; evidence tests; counterexample validation tests.
4	Reasoning integration	Context builder; redaction; provider abstraction; versioned prompts; fallback chain.	Provider tests including mock and failure paths; redaction tests.
5	Repair and verification	Deterministic templates; model repair; diff operations; sandboxed verification; proof-of-fix aggregation.	Patch tests; verification tests; proof-of-fix tests.
6	Product surface	API routers; schema and migrations; authentication and authorisation; organisations and tokens.	Route-level tests across twenty-two routers; security regression tests.
7	Interface	Next.js application across three route groups; components for evidence, remediation and verification.	Type checking, unit tests for domain helpers, and build in continuous integration.
8	Benchmark and deployment	Experiment runner and metrics; seeded fixtures and ground truth; containers, compose files, pipelines.	Benchmark tests; operational scripts and cadence workflow tests.

Source: author's reconstruction from the repository structure, module docstrings and documentation set.

The work proceeded in eight increments, and each produced a capability that could be exercised end to end before the next began. Ingestion and discovery came first, with the archive guards and the manifest. Structural analysis followed: the parser over three grammars, then the knowledge graph, then the architecture-smell analysis that the graph made possible. Detection and adjudication came next as a pair, because a rule without an adjudicator cannot be evaluated and an adjudicator without rules has nothing to judge. Reasoning support followed, adding the context builder, redaction, the provider abstraction and the nine versioned prompts. Repair and verification formed the fifth increment, and they too were paired: a generator without a verifier would have produced the very artefact this project exists to avoid.

The product surface came sixth, converting the engine into a service with routers, a schema, migrations, authentication and organisations. The interface came seventh. The benchmark and the deployment artefacts came last, and they are the increment that changed the project from a working application into an instrument, because they are what makes a claim about detection quality testable rather than rhetorical. The phases were not strictly sequential: verification was revisited whenever the evidence model changed, because the re-analysis step consumes the detector set and therefore inherits every rule refinement. That coupling is a design property rather than an accident — the pipeline's later stages are deliberately sensitive to earlier ones, which is what makes an end-to-end verdict meaningful.

The phases were not strictly sequential. Verification, for example, was revisited whenever the evidence model changed, because the re-analysis step consumes the detector set and therefore inherits any rule refinement. This coupling is a design property rather than an accident: the pipeline's later stages are deliberately sensitive to earlier ones, which is what makes an end-to-end verdict meaningful and also what makes the benchmark a useful instrument.

12. Testing Strategy

12.1 Approach

Testing is organised by risk rather than by file. The highest densities of test functions are in the areas where a mistake is either a security defect or a false claim: authentication and account security, security hardening and regression, billing and entitlements, team and sharing features, tiered workflow behaviour, and website crawling. The suite is written with an asynchronous test runner and a fixture harness that creates an isolated application, a throwaway database and a temporary storage root per test, so tests cannot leak state into one another or into a developer's working directory.

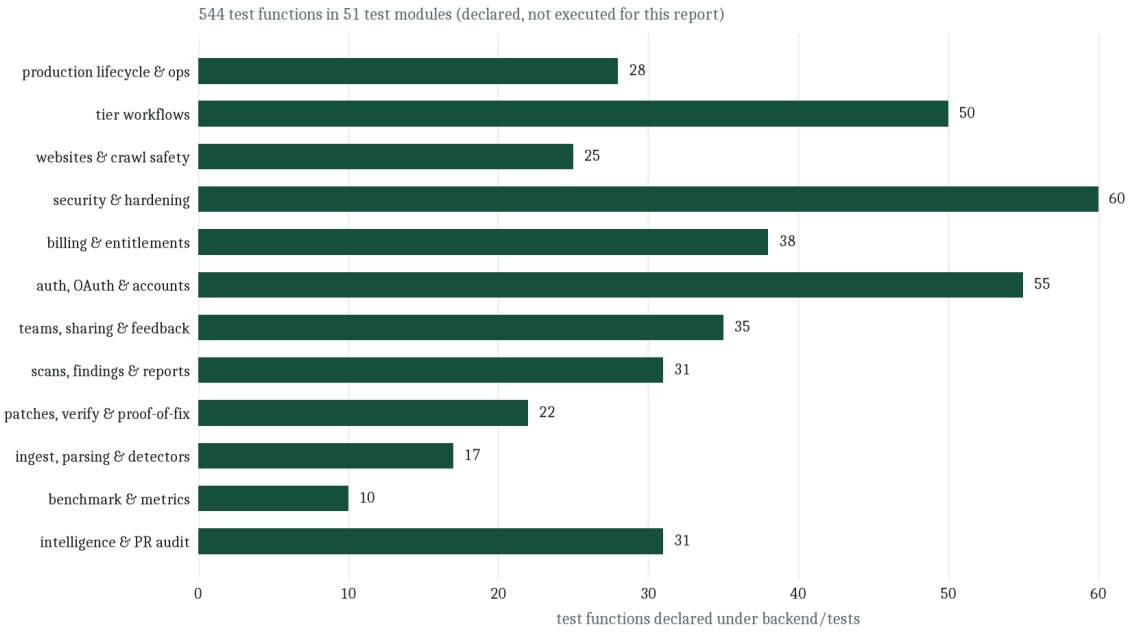


Figure 12. Distribution of test functions across the functional areas of the system
Source: Project repository — measured from backend/tests (544 test functions in 51 modules).

It is important to be precise about what this chapter claims. The repository declares five hundred and forty-four test functions. The suite was not executed while this report was being prepared, so this report does not state a pass count, a coverage percentage or a duration. What it can state, and does, is which behaviours the tests defend and how they are constructed. A supervisor who wishes to confirm the suite can run the documented command; the repository's own continuous-integration configuration runs the same command on every push, and the documentation records seventy-nine tests at the time the readme was written, which shows that the suite has grown substantially since.

12.2 Levels of testing

Table 14. Testing levels, technique and representative modules

Level	Technique	Representative modules
Unit	Direct calls to analysis functions with hand-built inputs and assertions on the returned value objects.	Detector tests, parsing tests, patch operations, benchmark metrics, SARIF rendering, redaction.
Contract	Route-level tests that assert status codes, response shapes and error semantics for a single endpoint.	Repository, scan, finding, patch, token, onboarding and dashboard route tests.
Integration	The real orchestrator over a fixture repository against a throwaway database, asserting persisted rows rather than return values.	Orchestrator tests, proof-of-fix tests, reporting tests, regression tests.
Security	Adversarial cases: path traversal, identifier enumeration, cross-user access, rate-limit exhaustion, injection-shaped input, webhook forgery.	Ingestion tests, hardening tests, security regression tests, adversarial business-logic tests, rate-limit tests, authentication webhook tests.
End to end	The documented flagship flow from sign-up through verification using a local execution runner instead of a container.	Verification tests, production lifecycle tests.
Operational	Scripts that check backups, dependency security, incident triage and the operations cadence, exercised against synthetic state.	Operational cadence tests, production operations tests, supply-chain tests.
Frontend	Unit tests for domain helpers, formatting and security utilities, plus type checking and a production build.	Domain, format, security and utility test files; type-check in continuous integration.

Source: Project repository — backend/tests and frontend/src (test files).

12.3 Test cases and expected outcomes

The table below records representative cases in the form used by the suite, with the expected outcome expressed as an assertion a reviewer could check by reading the module. Cases are grouped by the requirement they verify, which is what makes the traceability in Chapter 6 operational.

Table 15. Representative test cases with expected outcomes

Case	Input	Expected outcome	Trace
TC-01	An archive containing a member whose path is absolute.	Upload rejected with an unsafe-archive reason; nothing extracted outside the storage root.	FR-02, NFR-01
TC-02	An archive whose members contain parent-directory segments.	Upload rejected; storage directory remains empty.	FR-02, NFR-01
TC-03	A file uploaded with a .zip name but non-archive content.	Rejected at magic-byte validation before extraction.	FR-02
TC-04	A repository whose size exceeds the configured cap.	Rejected with a readable limit message; no partial working copy retained.	NFR-09

Table 15. Representative test cases with expected outcomes

Case	Input	Expected outcome	Trace
TC-05	A Python file containing a query assembled by f-string and executed on a cursor.	A finding with the SQL-injection rule identifier, the sink location and at least a source and sink evidence node.	FR-06, FR-10
TC-06	The same pattern expressed as a parameterised query.	No finding; the detector does not match a bound-parameter call.	FR-06
TC-07	A JavaScript module with a template-literal query passed to a client.	Findings for the secret and query rules with JavaScript-suffixed identifiers.	FR-06
TC-08	A file that the grammar cannot parse.	Scan continues; a warning is recorded; other files are analysed normally.	FR-05, NFR-09
TC-09	A scan started with no provider key configured.	Deterministic stages complete; the reasoning stage is recorded as failed with an explanatory message; no fabricated model findings.	FR-09, NFR-06
TC-10	A candidate whose sink is located but whose chain cannot be completed.	Persisted as probable rather than verified, with the partial chain recorded.	FR-10
TC-11	A candidate claim with no repository grounding.	Rejected; the candidate is counted but not published as a finding.	FR-10, NFR-06
TC-12	A template repair generated twice for an unchanged finding.	The second generation is idempotent; findings are de-duplicated on the stable identifier.	FR-12
TC-13	A generated diff whose target path escapes the repository root.	Patch rejected before storage with a structured error.	FR-13
TC-14	A patch that does not apply to the working copy.	Verification records a failure at the apply step; the sandbox is deleted.	FR-14
TC-15	A patch that applies, passes tests and removes the original rule.	Verification resolves to a verified repair with per-test results attached.	FR-14
TC-16	A patch that applies and passes tests but leaves the rule firing.	Verification does not resolve to a verified repair, demonstrating that tests alone are insufficient.	FR-14
TC-17	Verification requested when no container runtime is reachable.	Recorded as not verified with a runner-unavailable explanation, never as a success.	FR-14, NFR-06
TC-18	A second verification requested while one is in flight for the same patch.	Conflict response; no duplicate run is created.	FR-14
TC-19	A user requests a repository owned by another user.	The same response as an anonymous request; no existence disclosure.	NFR-07
TC-20	A member with the lowest role attempts to remove another member.	Refused by the ranked role comparison.	FR-18, NFR-07
TC-21	Repeated failed authentications beyond the configured budget.	Refusals with an increasing retry delay; no permanent lockout; the account bucket clears on success.	NFR-08
TC-22	A personal API token is created and then revoked.	Only the hash is stored; the plaintext appears once at creation; the revoked token is refused immediately.	FR-19
TC-23	A public share is created for a scan report.	The payload excludes credentials and internal log detail; the identifier is unguessable.	FR-16, NFR-03

Table 15. Representative test cases with expected outcomes

Case	Input	Expected outcome	Trace
TC-24	A website audit is requested for a hostname resolving to a private address.	Refused by the SSRF preflight before any request is issued.	FR-17
TC-25	A crawler encounters a disallowed path in robots.txt.	The path is skipped and reported; no request is issued for it.	FR-17
TC-26	A crawl is requested while an audit for the same site is running.	Conflict response; targets are never crawled concurrently.	FR-17
TC-27	A scan report is requested as Markdown.	A rendered document is returned whose contents match the structured report payload.	FR-15
TC-28	Findings are exported in the interchange format.	A valid document with rule identifiers, locations and severity levels.	FR-15
TC-29	Benchmark metrics computed for a configuration that produced no findings.	Ratios are undefined rather than zero; the renderer prints TBD.	FR-20, NFR-06
TC-30	A scan is cancelled while running.	The orchestrator stops at the next stage boundary and records the cancelled state.	FR-04

Source: Project repository — backend/tests (cases paraphrased from the modules; identifiers indicate the module area, not literal function names).

12.4 Testing the hard parts

Three subsystems resist ordinary testing and received specific treatment. The sandbox is tested through a runner seam: the verification engine accepts a runner object, production injects the container runner, and tests inject a local runner that executes the same steps against the sandbox copy. This means the verification logic — apply, baseline, tests, re-analysis, verdict — is exercised in continuous integration without a container daemon, while the container runner itself is a thin adapter whose behaviour is a configuration matter. The trade is documented rather than hidden: continuous integration proves the decision logic, not the isolation.

The model integration is tested with a deterministic mock provider and with explicit failure injection: a timeout, a malformed JSON reply, a provider error. Each is expected to leave the scan alive and to record the failure against the candidate rather than the scan. Prompt-injection resistance is tested at the assembly boundary — repository text must appear only inside the data section — and secret redaction is tested against representative key shapes.

The crawler is tested against the SSRF gate rather than against the public internet, because a test that depends on an external host is neither reproducible nor polite. The gate is exercised with private, loopback, link-local and metadata addresses, with redirect

chains that would land on a forbidden address, and with userinfo-bearing URLs. Refusal is the expected outcome in every case, and the tests assert that no request was issued, which is the property that actually matters.

12.5 What the test suite cannot prove

A test suite proves that specified behaviour holds; it cannot prove that the specification is right. Four things remain outside its reach and are stated here so that no later chapter quietly assumes them. Detection quality — whether the rules find real defects without excessive noise — is a property of the corpus, not of the code, and is measured only by the benchmark. Repair correctness in the general case depends on the quality of the project's own tests, which varies per repository. Isolation is a property of the container configuration, which the seam-based tests deliberately substitute. And performance under load is not measured at all, because the documented deployment is single-instance and the system makes no throughput claim.

Recording these gaps is not a concession; it is the same discipline the system applies to findings. A verification that could not establish a verdict is reported as such rather than as a pass, and a report about a verification system ought to hold itself to the standard it documents.

13. Evaluation Methodology

13.1 Research questions and hypotheses

The project defines four research questions and four matching hypotheses. They are stated in the repository's documentation in the same form used here, and the four audit configurations exist to answer them.

Table 16. Research questions, hypotheses and the comparison that tests each

RQ	Question	Hypothesis	Comparison
RQ1	How does repository-level context affect what a model can say about a defect?	H1 — structural context improves detection quality.	Model-only versus the full configuration.
RQ2	Does combining static evidence with model reasoning beat either alone?	H1 — the combination is better than either part.	Model-only versus the hybrid configuration.
RQ3	Does evidence validation reduce false positives?	H2 — validation removes ungrounded claims.	Raw candidate claims versus adjudicated findings, using the rejected-candidate count.
RQ4	Does execution-based verification improve repair correctness?	H4 — execution separates real fixes from plausible ones.	Template repairs versus model repairs, scored by verification outcome.

Source: Project repository — README.md (research questions) and docs/experiments.md (hypothesis mapping).

13.2 The benchmark apparatus

The apparatus is deliberately small and fully specified. Two fixture repositories ship with the project. The Python fixture is a deliberately vulnerable demonstration application containing six annotated defects: an injected SQL query, a hardcoded credential, a shell invocation with a constructed command, an evaluation of caller-supplied input, a weak hash used for token fingerprinting, and a broad exception handler that swallows errors. The JavaScript fixture contains four annotated defects: a hardcoded secret, a concatenated query, an interpolated command and a dynamic evaluation. Each defect is recorded in a ground-truth file with its file, function, starting line, rule family, severity, category and description. Every credential in both fixtures is fake, and the documentation states plainly that neither repository must ever be deployed.

The experiment configuration declares the two repositories, their ground-truth files, the four configurations and a line tolerance of six lines for location matching. Each pair of repository and configuration is executed against the real orchestrator with a throwaway database and an isolated storage directory, so an experiment cannot contaminate the development environment. For each pair the runner writes a JSON artifact containing the

findings, the stage-by-stage outcome, token usage and the reproducibility block, and a summary document containing the comparison table.

13.3 Metrics and matching rules

Scoring is defect-level with greedy one-to-one matching. A finding matches a ground-truth defect when three conditions hold: the file matches, the rule family matches — with language variants of the same family comparing equal, so a JavaScript injection finding matches the JavaScript ground-truth entry rather than the Python one — and either the enclosing function matches or the line falls within the tolerance window. Each defect can be matched at most once and each finding at most once, so a system that reports the same defect five times does not thereby improve its recall.

Table 17. Metrics, definitions and the denominator that makes each undefined

Metric	Definition	Undefined when
Precision	True positives divided by the sum of true and false positives.	No findings were produced at all.
Recall	True positives divided by the total number of annotated defects.	The ground truth contains no defects.
F1	Harmonic mean of precision and recall.	Either precision or recall is undefined.
False-positive rate	False positives divided by all findings.	No findings were produced.
Patch correctness	Proportion of generated patches that are the intended correction.	No patches were generated, or no reference correction exists for the repository.
Verification success	Proportion of verification runs that resolve to a verified repair.	No verification run was executed.

Source: Project repository — backend/app/benchmark/metrics.py and docs/experiments.md.

The rule that undefined quantities remain undefined is worth emphasising because it is the mechanism that keeps the evaluation honest. A naive implementation returns zero for precision when there are no findings, which reads as catastrophic performance; the more serious error is to return one, which reads as perfect performance. Both are fabrications. Returning an explicit absence forces the summary to display TBD, and TBD cannot be quoted in a results table as though it were a measurement.

13.4 Protocol and controls

Four controls protect the comparison. The same orchestrator runs all four configurations, so no arm uses a different code path for detection. The same ground truth scores all four arms, so no arm is judged against a friendlier standard. Each run receives a fresh database and storage directory, so state cannot leak between arms. And the reproducibility block

records the analyzer version, prompt version, model identity, tool versions, repository commit and timestamp, so a reported number can be traced to the configuration that produced it.

One control is missing and is the most important gap in the evaluation design: repeated runs. Model output is not deterministic across providers and versions, so a single run per cell cannot separate an effect from noise. The documentation does not claim otherwise, and the recommended extension is to run each cell several times and report a distribution rather than a point. This report records that recommendation as part of the methodology rather than presenting a single run as though it were an estimate.

13.5 Threats to validity

Construct validity is threatened by the fact that the ground truth was authored alongside the detectors. A rule set tuned on the same defect shapes that the annotations describe will look better than it would on an independent corpus. The mitigation available within the project is transparency: the ground-truth files are in the repository, so a reader can see exactly what is being measured and discount accordingly.

External validity is threatened by scale and by language. Ten annotated defects across two small fixtures cannot support a general claim about repository auditing, and the two fixtures cover only two of the three parsed languages. Internal validity is threatened by the single-run protocol described above, and by the dependency of the hybrid arms on provider behaviour that may change between the run and the reading. Conclusion validity is threatened by the small number of matching decisions: a difference of one finding moves precision by several percentage points on a corpus of this size, so differences must be large before they mean anything.

These threats are stated rather than mitigated because the honest position for a prototype is that its apparatus is sound and its corpus is small. The apparatus is the contribution this report can defend; the corpus is the first item on the list of future work.

14. Results

14.1 How to read this chapter

This chapter reports what exists and what does not, in that order. The system's measurable artefacts — code, routes, tables, tests, fixtures, rules, document set — are reported with exact counts because those counts are verifiable by opening the repository. The experimental results, which require executing the benchmark matrix with a configured provider, are reported as pending with explicit TBD markers because they have not been executed. There is no third category. No value in this chapter is estimated, interpolated or extrapolated from a related system.

14.2 Artefact measurements

Table 18. Measured size and composition of the delivered system

Artefact	Quantity	How it was counted
Backend application modules	27,657 lines of Python	All files under the backend application package.
Analysis-engine modules	45 modules, 13,402 lines	Files in the analysis package, including the package initialiser.
Database tables	28 mapped tables	Table declarations in the model module.
Migration revisions	10	Files in the migration versions directory.
HTTP route declarations	112 across 22 routers	Route decorators across the API route modules.
Prompt templates	9 versioned files	Files in the prompt directory.
Test functions	544 in 51 modules	Test function declarations across the test package.
Frontend modules	124 TypeScript files	Source files under the frontend source tree, excluding configuration.
Frontend source	22,580 lines	TypeScript and TSX source files.
Interface routes	40 pages	Page modules across the three route groups.
Documentation	13 documents, 1,660 lines	Markdown files in the documentation directory, excluding the readme and security notes.
Benchmark fixtures	2 repositories, 10 annotated defects	Fixture directories and their ground-truth files.
Built-in detection rules	11 rule identifiers	Rule declarations in the detector module, including language variants.

Source: Project repository — measured directly from the working tree (files, lines and declarations counted, not estimated).

Two observations follow from the table. The first is that the analysis engine is roughly half the backend by line count, which is consistent with the project's claim that analysis is the core and the API is a projection of it. The second is that the test suite is larger, in

declarations, than the route surface it defends, which is unusual for a prototype and is the strongest available evidence that the security and honesty properties described in earlier chapters are enforced rather than asserted.

14.3 Experimental results

The benchmark matrix has eight cells: two repositories against four configurations. None of the eight has been executed for this report, because the model-dependent configurations require a provider key and the static configuration, while runnable without one, has not been run in this documentation pass. The table below is the exact form the summary takes when no run exists, which is also the form the repository's own documentation publishes.

Table 19. Detection and repair comparison across the four configurations

Configuration	Precision	Recall	F1	False pos. rate	Patch correct.	Verif. success
Static only	TBD	TBD	TBD	TBD	Not applicable	Not applicable
Model only	TBD	TBD	TBD	TBD	TBD	TBD
Static and model	TBD	TBD	TBD	TBD	TBD	TBD
RepoVeriX (full)	TBD	TBD	TBD	TBD	TBD	TBD

Source: Project repository — docs/experiments.md (expected comparison table). All cells pending experimental execution.

The static-only row records patch correctness and verification success as not applicable rather than TBD because that configuration produces detection output only; it does not generate or verify repairs. This is a meaningful distinction: not applicable is a statement about the design, whereas TBD is a statement about missing data, and a results table that conflates them misleads the reader about what remains to be done.

For completeness, the qualitative expectation the project records — and which this report reproduces as an expectation rather than a result — is that the full configuration should improve precision over the static configuration by rejecting ungrounded candidates, and should improve repair trust over an unverified repair pipeline by refusing patches that do not survive execution. Whether those expectations hold, and by how much, is precisely what the eight unexecuted cells would show.

14.4 Results that are qualitatively demonstrable

Three properties can be demonstrated from the repository without running the benchmark, and each is worth separating from the pending quantitative work. First,

graceful degradation is observable in code and in the scan summary schema: the reasoning stage records `llm_unconfigured` when no key is present, and the deterministic findings still complete. Second, the evidence chain is a persisted artefact rather than a rendered sentence — it is a table with an ordering index, populated by the adjudicator, and a reviewer can query it directly. Third, the verification engine's refusal to declare success on tests alone is visible in the outcome vocabulary: the re-analysis flag is part of the recorded run, and a run where the rule still fires cannot produce a verified repair.

Table 20. Qualitative properties and the mechanism that makes each demonstrable

Property	Mechanism	Where to verify
Degradation is recorded, not hidden	Per-stage analysis rows with status and output payloads.	Scan detail response and its analysis-run records.
Evidence is addressable data	Ordered evidence rows with kind, location and metadata.	Evidence table and the finding detail response.
Tests alone cannot verify a repair	Re-analysis of the original rule is a separate, recorded condition.	Verification run fields and the outcome vocabulary.
No metric is fabricated	Undefined ratios propagate as null and render as TBD.	Metric module and the summary renderer.
Original repositories are never mutated	Repairs are diffs; verification works on a copy that is deleted afterwards.	Verification module and the storage layout.
Untrusted content stays data	Fixed system prompt, delimited data sections, redaction before transmission.	Prompt templates and the redaction module.

Source: Project repository — schema, module interfaces and documentation.

14.5 Discussion

The pattern that emerges from the artefact measurements is that this project spent its effort on the parts of an auditing system that are usually skipped. Detection rules are comparatively cheap to write; the expensive parts are the adjudication that decides what a rule's firing means, the verification that decides whether a repair is real, and the bookkeeping that keeps an honest record when a stage cannot run. The repository's proportions reflect that priority, and the evaluation apparatus — eight cells, one fresh database each, ground truth per defect — is the natural counterpart: a system that insists on evidence for its findings also needs evidence for its own performance claims.

The limitation of this chapter is therefore not a shortfall of the system but a limit of the documentation pass. The benchmark exists, the fixtures are annotated, the metrics are implemented and the reporting is wired; what is missing is a configured provider and a quiet hour. The correct response to that situation is to publish the table with TBD in every cell and say so plainly, which is what the repository already does and what this chapter has reproduced.

14.6 Reproduction procedure

For a reader who wishes to convert the pending cells into measured ones, the procedure is documented in the repository and involves no modification to the code. The backend environment is installed from the packaging metadata, a provider key is placed in the environment file, the experiment list is enumerated to confirm which repositories and configurations the runner sees, and the run command is issued against the experiment configuration with the reports directory as output. The runner writes one artifact per cell and a summary document. The summary document is the table in this chapter with the TBD cells replaced by computed values.

Two cautions belong with that procedure and are recorded in the repository's own documentation. A run without a provider key will complete the static arm and record the model arms as failed rather than producing numbers, which is the intended behaviour and not a bug. A single run per cell is a demonstration rather than an estimate, so a defensible result requires several repetitions per cell and a reported distribution, as noted in the threats to validity.

15. Limitations

15.1 Functional limitations

The system analyses three languages. A repository written in Java, Go, Rust or C# will be ingested, inventoried and subjected to the dependency and history analyses, but it will not be parsed into symbols, so no structural rule will fire and no repair will be generated. This is a hard boundary rather than a degradation: the discovery manifest will show the languages it detected, and the absence of findings on an unsupported repository is not evidence that the repository is clean. The interface and the report both make this distinction visible, but a reader who scans quickly can still draw the wrong conclusion, and that is a limitation of the presentation as much as of the engine.

Detection is rule-bound. The eleven shipped rules cover injection, secrets, command construction, dynamic evaluation, weak hashing and error swallowing. They do not cover authorisation logic, race conditions, deserialisation, path handling or business-logic flaws, which are the categories where modern application defects most often live. The model can propose claims about those categories, and the adjudicator can accept them if the repository provides grounding, but there is no deterministic rule to anchor the claim, so such findings are more likely to land at probable than at verified. The system is honest about this through its status semantics rather than by pretending the coverage is uniform.

15.2 Evidence depth

The knowledge graph resolves symbols, imports and single-hop call relationships. That is enough to establish that a function is called by a route handler, which is a substantial improvement over pattern matching alone. It is not enough to follow a value through three functions, a dictionary, a queue and a template. Chains that cross such boundaries terminate in partial evidence and the finding is downgraded accordingly. The consequence is a systematic bias toward shallow, local defects in the verified category and a residual population of deep defects in the probable category — a bias that any evaluation of this system should measure rather than assume away.

Counterexample validation mitigates one specific failure, which is a sanitiser sitting between source and sink. It does not attempt a general proof of safety. A finding that survives adjudication has evidence supporting it; it does not have a proof that it is exploitable, and the report avoids the word *confirmed* for exactly that reason.

15.3 Operational limitations

Scans run in the process that serves the API. A long scan occupies a worker, a restart interrupts running work, and the recovery mechanism can only mark interrupted jobs rather than resume them. Rate limiting is held in memory, so the limits are per process. These choices are documented as deliberate for a single-instance deployment, and the code isolates them behind seams, but they bound the system's usefulness beyond a small number of concurrent users and they are the reason no throughput claim appears anywhere in this report.

Verification requires a container runtime. Without one, every verification resolves to not verified, which is honest but unhelpful; the system's most distinctive capability is therefore unavailable in the simplest deployment. The deployment documentation describes mounting the daemon socket and warns, in the same paragraph, that doing so grants control of the daemon and should be confined to a dedicated host. That warning is a limitation of the architecture, not a documentation defect: running untrusted code safely is expensive and the project chose to be explicit about the cost.

15.4 Evaluation limitations

The benchmark corpus is two small fixtures with ten annotated defects. Every metric in the pending table is a ratio over that corpus, which means a single matching decision can move a percentage by several points. The ground truth was authored by the same project that authored the detectors, which raises the possibility of a favourable bias. And the protocol specifies one run per cell, which cannot separate an effect from provider noise. None of these is hidden; all three are recorded in the repository's experiment documentation and in Chapter 13 of this report.

A further limitation concerns what the benchmark does not measure. It measures whether findings match annotated defects; it does not measure whether a reviewer's time was saved, whether a finding was actionable, or whether the evidence chain was comprehensible. Those are the questions that determine whether a tool of this kind is adopted, and they require a user study rather than a corpus.

15.5 Limitations of this report

This document was written from a repository checkout without executing the application, the test suite or the benchmark. Statements about implemented behaviour therefore rest

on source and documentation rather than on observed execution, and are labelled accordingly. No screenshot was fabricated: the figures in this report are conceptual diagrams generated from verified repository facts, and the report says so in every caption. A reader who wants observed behaviour should run the documented flows; the repository is structured to make that straightforward, and Chapter 14.6 gives the procedure for the benchmark.

16. Ethical and Security Considerations

16.1 Handling other people's code

A system that audits repositories is entrusted with source code that may be confidential, may contain secrets, and may belong to someone other than the person operating the tool. Three commitments follow, and all three are implemented rather than aspirational. The original repository is never modified: ingestion produces a working copy, repairs are diffs, and verification operates on a sandbox copy that is deleted afterwards. Secrets are redacted before content leaves the process, so a provider never receives the credential that a finding is about. And execution of untrusted code is confined to a container with resource limits, no host secrets and no mounts beyond the sandbox directory.

The second commitment deserves emphasis because it is counter-intuitive. The system detects hardcoded credentials, which means it necessarily reads them. The correct behaviour is to report that a secret exists at a location, not to transmit its value to a third party. Redaction is therefore applied to every snippet used in prompt construction, and the share mechanism assembles a sanitised payload that excludes credentials and internal log detail. Detecting a secret is the finding; exfiltrating it would be an incident.

16.2 Responsible handling of vulnerabilities

The tool produces statements about weaknesses in software. Those statements can be wrong in either direction, and each direction has an ethical dimension. A false positive wastes a maintainer's time and, if published, can damage a reputation. A false negative creates false reassurance. The design response is the status vocabulary: verified means repository evidence supports the claim, probable means partial support, and rejected means insufficient grounding and is not shown as a confirmed vulnerability. Confidence is labelled as a system score rather than a probability, because an uncalibrated number presented as a probability is a form of false precision.

Two further practices belong here. Findings are de-duplicated on a stable identifier so that re-running a scan does not inflate a count, and rejected candidates are counted rather than discarded, so the ratio of rejection is visible to the reviewer. Both are small decisions that make the output harder to misrepresent, which is the ethical property that matters for a tool of this kind.

16.3 Website auditing ethics

The website subsystem is bound by a stricter rule than the repository subsystem because its target is someone else's server. It reads only what any visitor could read: same-origin pages, public response headers, robots.txt, and the HTML the server chooses to send. It never authenticates, never fuzzes, never sends destructive requests, and never follows a link off the registered hostname. It honours robots.txt, waits between requests, caps the crawl at twenty-five pages and three levels of depth, and refuses to run two audits against the same site concurrently. The politeness delay and the page cap exist for the target's sake, not for the auditor's.

The output is constrained in the same spirit. Scores are labelled as the project's own analytical scores; the performance dimension explicitly is not a Lighthouse run and produces no Core Web Vitals; the accessibility checks are automated DOM checks rather than a conformance audit; and a high score is not a security certification. Where evidence is insufficient, the score is null and the finding carries an insufficient state. A tool that told a client their site had an eighty-three out of a hundred and left it at that would be making an implicit claim about a third party's ranking methodology; this one refuses to.

16.4 Privacy and data protection

The account model stores a hashed password, never the password itself, and stores personal API tokens only as a hash, with the plaintext shown once at creation. Authentication events are recorded in an audit trail for security review. Accounts support export and deletion of the caller's own data, and deletion cascades through repositories, scans, findings, evidence, patches and verification runs so that removing an account removes the derived artefacts rather than orphaning them. Email verification is required before repository registration and scanning, which prevents an unverified address from being used to consume compute.

Two operator obligations sit outside the code and are recorded in the setup documentation. The credentials in the environment file are secrets and must not be committed; the repository ships only a template with placeholders. And the deployment must not mount the container daemon socket on a shared host, because that mount is equivalent to granting control of the daemon.

16.5 Academic integrity and honest reporting

This report was produced from a repository checkout. Where the repository supplied a fact — a route, a table, a limit, a rule identifier — the report states it and names the file it came from. Where a number required an experiment that was not run, the report writes TBD. Where a behaviour exists only in documentation because it depends on an external service, the report marks it documented and excludes it from results. Nowhere does the report claim that the test suite passed, because it was not executed during this pass; nowhere does it present an estimate as a measurement.

Integrity also applies to the figures. Every diagram in this report was generated from verified repository facts — module inventory, route counts, documented stage order, model definitions — and every caption records that provenance. No screenshot was fabricated, no interface was mocked up, and no stock imagery was used. A reader can therefore treat the figures as claims of the same kind as the text: checkable against the repository they describe.

16.6 Research ethics of the benchmark

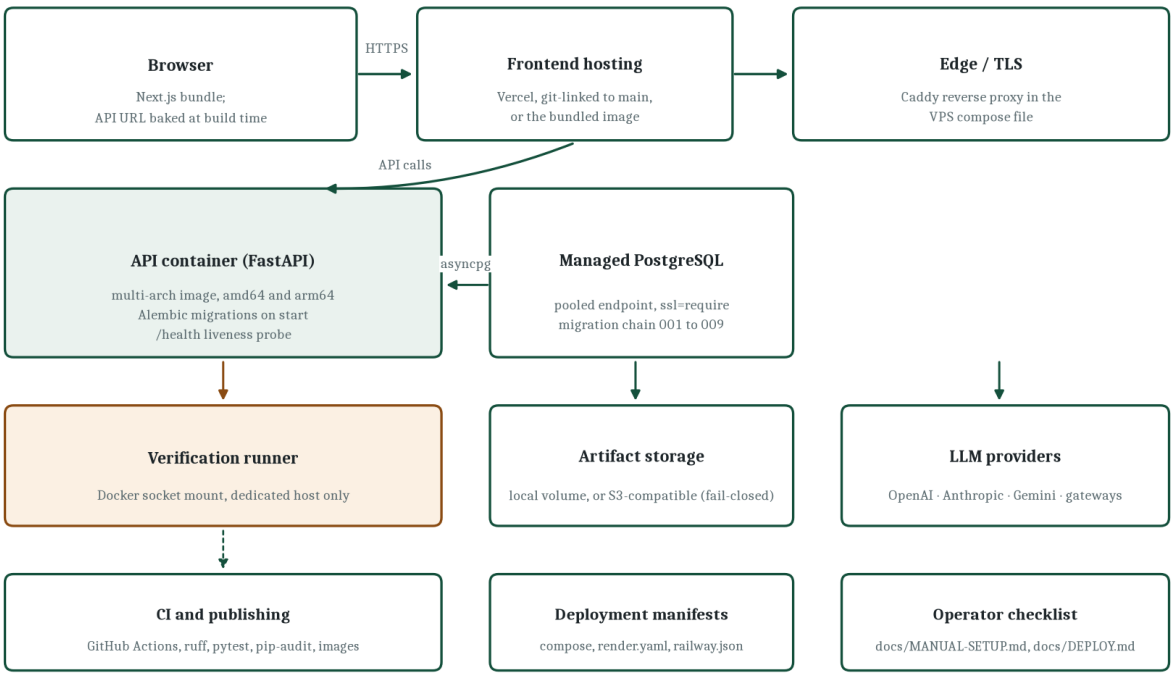
The benchmark fixtures are deliberately vulnerable programs. Their credentials are fake, their defects are annotated, and the documentation states in the readme, in the fixture readme and in the experiment documentation that they must never be deployed. This is the standard precaution for a vulnerability corpus, and it is repeated rather than assumed because a fixture that escapes into a deployment is a real vulnerability with a public repository attached to it.

The second ethical question is whether publishing a benchmark tuned to one's own detectors constitutes a claim of general performance. It does not, provided the corpus is described honestly, and the repository's experiment documentation does exactly that: it states the size, the languages, the defect families and the fact that metrics are computed only from real runs. This report reproduces that description in Chapter 13 and repeats the threats to validity in Chapter 15 rather than leaving them for a reader to infer.

17. Deployment and Maintenance

17.1 Topology

The repository documents two deployment shapes. The simple one is a single compose stack of three services — a frontend, an API and a PostgreSQL database — with a local volume for repository storage and an optional container daemon mount for verification. It is intended for evaluation and for a single-operator host. The recommended production shape separates the concerns: the frontend on a managed static-edge host linked to the main branch, the API on a small virtual server pulling a published image, the database on a managed service with a pooled endpoint, and artifact storage on an S3-compatible store when more than one API instance is required.



Source: docs/DEPLOY.md, docker-compose.vps.yml, render.yaml, railway.json, .github/workflows.

Figure 13. Deployment topology: hosting, API, database, verification runtime and supporting services

Source: Project repository — docs/DEPLOY.md, docker-compose.vps.yml, render.yaml, railway.json.

17.2 Build, publish and release

Continuous integration runs two jobs on every push and pull request. The backend job installs the package with development extras, checks formatting, lints, runs the test suite and performs a dependency vulnerability audit whose failures are surfaced but do not block the build. The frontend job installs from the lockfile, lints, type-checks, runs its unit tests and produces a production build. A successful push to the main branch additionally

builds multi-architecture images for both services and publishes them to the container registry, so a server pulls a tested artefact rather than building on the host.

Table 21. Deployment artefacts in the repository

Artefact	Purpose
Root Dockerfile and per-service Dockerfiles	Reproducible images for the API and the frontend, multi-architecture for both common server platforms.
docker-compose.yml	Local development stack for the three services.
docker-compose.prod.yml	Production-oriented stack with migration on start and a health check.
docker-compose.vps.yml	Single virtual-server variant that pulls published images and terminates TLS through a bundled reverse proxy.
Caddyfile and nginx configuration	Reverse proxy and static serving rules.
render.yaml and railway.json	Blueprint manifests for two alternative hosting platforms.
Environment templates	Placeholders for every variable, with production-specific guidance in a second template.
Operator scripts	Provisioning, backup verification, dependency security check, incident triage, monitoring and release preparation.

Source: Project repository — Dockerfile, backend/Dockerfile, frontend/Dockerfile, compose files, deployment guides.

17.3 Configuration

All backend settings are environment variables behind a single prefix, read through one settings object, with defaults chosen so that a development environment starts without configuration. The variables group into database and storage, execution limits, model access, authentication and account security, email, rate limiting, billing, artifact storage and observability. Two properties of the design make this manageable: every limit mentioned in this report corresponds to a named setting rather than a scattered constant, and the repository ships a classification of each production variable as public or secret in the production template.

Table 22. Representative configuration settings and their defaults

Setting	Default	Effect
Repository size cap	100 MB	Upper bound on an ingested repository; exceeding it fails the ingestion stage with a readable error.
Per-file size cap	1 MB	Bounds a single source file that the parser will read.
File count cap	5,000	Bounds the number of files extracted from an archive.
Symbol count cap	20,000	Bounds the symbol index; exceeding it degrades gracefully.
Sandbox CPU limit	1.0	CPU shares granted to a verification container.
Sandbox memory limit	1 GB	Memory ceiling for a verification container.
Sandbox timeout	600 s	Wall-clock ceiling for a verification run.

Table 22. Representative configuration settings and their defaults

Setting	Default	Effect
Sandbox network	bridge	Container networking; can be set to none for a fully offline verification.
Model candidates per scan	60	Upper bound on candidates sent for reasoning, which bounds cost.
Model context characters	24,000	Upper bound on the assembled context package per candidate.
Authentication attempts	8 per 5 min	Rate-limit budget for sign-in and sign-up, keyed by client and account.
Authentication backoff	30 s to 1 h	Progressive delay after repeated refusals, doubling to a ceiling.
User API budget	600 per min	Rate-limit budget for an authenticated caller.
Crawl page cap	25	Maximum pages in a website audit, with a default of ten.

Source: Project repository — backend/app/core/config.py and .env.example.

17.4 Operations and maintenance

The repository treats operations as a first-class concern rather than an appendix. Seven operator scripts cover database backup, backup and point-in-time recovery verification, dependency security checking, incident triage, monitoring and alerting configuration, an operations cadence review and release preparation. An operational-defect issue template captures the information needed to triage an incident, and a scheduled workflow runs the operations cadence so that the review happens whether or not anyone remembers it. Startup recovery marks jobs that a process death left in a running state, so the interface never shows a job that will not complete.

Maintenance of the analysis engine itself has three predictable dimensions. Rules age: a hash primitive or an API shape that is acceptable today may not be tomorrow, so the rule catalogue and its documentation must be revised together. Prompts age faster, because provider models change under a fixed prompt; this is why prompt files are versioned and why the version is recorded on every scan, so a change in output can be attributed to a change in configuration rather than to a change in behaviour. And languages age, in the sense that a new grammar version changes node types; the parser abstraction confines that cost to the language mapping.

Backups deserve a specific note because the system stores more than rows. Repository storage holds uploaded archives and extracted working copies, and a database restore without the corresponding storage directory produces scans whose files cannot be re-read. The backup script and the recovery verification script exist together for that

reason, and the deployment guide states that both stores must be captured.

17.5 Scaling path

The documented path from single instance to a small cluster follows the seams described in Chapter 7 rather than requiring a rewrite. Move artifact storage to the S3-compatible adapter, which is already implemented and fails closed if credentials are missing rather than silently falling back to local disk. Replace the in-process scheduler with a durable queue behind the existing interface. Replace the in-memory rate limiter with a shared backend exposing the same three operations. Then run more than one API worker. Each step is a substitution of an implementation rather than a change of architecture, which is the practical benefit the monolith's seams were designed to provide.

18. Future Enhancements

18.1 Recorded direction

The repository lists its intended direction in the readme, and this chapter expands that list rather than inventing a different one. Each item is stated with the reason it matters and the part of the current design it would change, so that a reader can judge feasibility rather than take a wish list on trust.

Pull-request gating and continuous-integration integration. The system already audits a change set: it computes a diff for a base and head reference, scores the blast radius, checks for missing companion changes and can post a summary to a pull request. What is missing is the enforcement path — a status check that fails a build when a verified-repair-pending finding is introduced, and a policy layer that decides which rules are blocking. This is the highest-value next step because it moves the audit from on-demand to continuous, which is where developers actually encounter it.

An editor extension or model-context-protocol server. The API is already a complete description of the capabilities, and a token model exists for headless access. A thin client inside the editor would let a developer see the evidence chain next to the code, which is the natural place for it. The risk is latency: an audit is not an editor-time operation, so the useful design is to surface existing findings and request a scan, not to scan on every keystroke.

Additional languages. The parser abstraction makes a language an addition of a grammar and a node mapping, and the rule set already carries language variants for two of the three supported languages. Java, Go and C# would each require node mappings, a set of rule variants and a repair template for the parameterised-query case. The dependency and history analyses would work unchanged because they do not depend on the parser.

18.2 Deepening the evidence

Inter-procedural data flow. The most valuable single improvement to the system's precision would be propagating taint across function boundaries with summary-based analysis: for each function, compute which parameters reach which sinks, then compose summaries along the call graph. The knowledge graph already provides the edges. The work is in the summaries, the treatment of containers and fields, and the handling of

dynamic dispatch — and the payoff is that deep defects currently downgraded to probable would become verifiable.

Semantic retrieval over the repository. Context assembly currently uses graph proximity: the enclosing function, its callers and callees, its imports. Embedding-based retrieval would add a different signal — other functions in the repository that address the same concern — and could improve the model's judgement on defects that are not visible in a single call chain, such as a validation convention honoured in nine handlers and violated in a tenth. The cost is an index that must be maintained and a retrieval quality problem that is itself an object of study.

Vulnerability-database correlation. Dependency inventory already records ecosystem, name, version and development flag. Correlating those with published advisories would extend the audit from code to supply chain, and the reachability analysis already answers the question that makes such correlation actionable: does this repository actually import the vulnerable package, or does it merely declare it?

18.3 Scaling the evaluation

A broader benchmark. The apparatus is complete and the corpus is small. The most defensible next step for the research claim is to add repositories: real open-source projects with published defects, synthetic repositories seeded with defect families the current fixtures do not cover, and at least one repository per supported language. The ground-truth schema already supports this, and the runner takes repositories from the experiment configuration rather than from a hardcoded list.

Repeated runs and statistical reporting. A single run per cell cannot separate an effect from provider noise. Repeating each cell and reporting a distribution, with the provider identity and version recorded per run, would turn the comparison table from a demonstration into evidence. The reproducibility block already captures what is needed to attribute a difference to a configuration change.

A user study. The questions that determine adoption are not answered by precision and recall. Does the evidence chain let a reviewer reach a decision faster than a scanner list? Do reviewers trust a verified repair more than an unverified diff, and should they? Does the rejected-candidate count change how a reviewer reads the verified ones? These are empirical questions about comprehension, and they need practitioners rather than a corpus.

18.4 Engineering maturity

A durable job queue. Replacing the in-process scheduler with a queue would make scans survive a restart, allow more than one worker, and let long verification runs be retried with backoff. The interface behind which this change happens already exists, which is why the item appears under engineering maturity rather than under re-architecture.

Deeper verification oracles. Verification currently consults three oracles: the project's tests, a static baseline and a re-analysis. Two additions would strengthen it. Differential testing, where the patched and unpatched versions are exercised on generated inputs and their observable behaviour compared, would catch behaviour changes that the test suite does not cover. And a mutation-style check, where the original defect is reintroduced to confirm that the tests would have caught it, would tell a reviewer whether a passing verdict is meaningful — a particularly valuable signal for repositories with thin test suites.

Team collaboration and continuous monitoring. Organisations, membership roles and shared reports exist; what does not exist is a scheduled re-audit with change notification, and a triage workflow with assignment and state. Both are ordinary product work rather than research, and both depend on the queue above.

Table 23. Future work, prioritised by dependency and value

Enhancement	Depends on	Effort	Value
Pull-request gating in continuous integration	Existing change-audit and pull-request modules	Moderate	Moves auditing from on-demand to continuous; highest adoption impact.
Durable job queue	Existing scheduler seam	Moderate	Enables multiple workers, restart survival and retries.
Broader benchmark corpus and repeated runs	Existing runner and ground-truth schema	Low to moderate	Converts the pending comparison into defensible evidence.
Inter-procedural data flow	Knowledge graph and evidence model	High	Moves deep defects from probable to verified.
Additional languages	Parser abstraction and rule variants	Moderate per language	Broadens applicability beyond three languages.
Semantic retrieval for context	New index and evaluation	High	Improves judgement on repository-wide conventions.
Differential and mutation oracles	Sandbox runner	Moderate	Makes a verified verdict meaningful on thin test suites.
Editor or agent-protocol integration	Token-authenticated API	Moderate	Puts evidence next to the code.

Source: Project repository — README future-work section, expanded by the author.

19. Conclusion

This report has documented RepoVeriX, a research prototype for repository-level code auditing and verified automated repair, from its problem statement through its architecture, data model, interface, testing, evaluation design and deployment. The system's contribution is best stated as a discipline rather than a feature. It insists that a claim about a defect be accompanied by repository evidence, that a claim about a repair be accompanied by the execution that established it, and that a stage which could not run be recorded as such rather than papered over with a plausible number. Those three commitments shape almost every design decision described in these chapters, from the ordering of the evidence chain to the vocabulary of verification outcomes to the decision to render an undefined ratio as TBD.

19.1 What was built

The delivered artefact is a complete three-part application. A FastAPI backend of roughly twenty-eight thousand lines implements ingestion, parsing, structural analysis, deterministic detection, context assembly, model interaction, evidence adjudication, repair generation and sandboxed verification, and exposes them through one hundred and twelve route declarations across twenty-two routers. A PostgreSQL schema of twenty-eight tables persists the audit spine and the surrounding capability surface, with ten migration revisions and SQLite support for development. A Next.js interface of forty routes and roughly twenty-two and a half thousand lines presents findings as case files rather than alerts, with the evidence chain and the verification log visible in place. A benchmark harness with two annotated fixtures and four configurations completes the apparatus, and five hundred and forty-four test functions defend the behaviours the system relies on.

The analysis engine is the centre of gravity at forty-five modules and thirteen and a half thousand lines, and within it the evidence model and the verification engine are the parts that distinguish the project. The evidence model converts a candidate into an adjudicated finding with an ordered chain of typed nodes, asserting the minimum required evidence in code so that a model's assertion can never be sufficient. The verification engine converts a candidate patch into a verdict by applying it to a disposable copy, comparing a static baseline, running the project's tests in a resource-limited container and re-analysing the original finding — and by refusing to declare success when the rule still fires, even if every

test passes.

19.2 What was demonstrated

Six properties are demonstrable from the repository itself and have been documented in the preceding chapters with their mechanism. Repository content never executes on the host during analysis. Secrets are redacted before content reaches a model provider. A scan records every stage, including the stages that failed and why. A finding carries an ordered evidence chain that a reviewer can inspect node by node. A repair is verified by execution or reported as not verified, never assumed. And no metric is fabricated: undefined quantities propagate as null and appear as TBD.

Six corresponding limits have been stated with equal precision. Three languages are parsed and no more. Evidence depth is single-hop, so deep defects are downgraded. Scans run in-process, so throughput is bounded. Verification needs a container runtime and is unavailable without one. The benchmark corpus is small and was authored alongside the detectors. And the quantitative comparison across the four configurations has not been executed, so every cell in the results table reads TBD. The report has resisted the temptation to fill those cells with an expectation dressed as a measurement, because a document arguing for evidence-grounded claims cannot itself rely on unevidenced ones.

19.3 What the work suggests

Three observations seem worth carrying beyond this project. The first is that the interesting engineering in an AI-assisted security tool is not the model call but the adjudication around it. A prompt is a few dozen lines; the evidence model that decides what a prompt's output is permitted to mean is where the reliability of the system actually lives. The second is that honesty is an architectural property, not a tone of voice. Recording a failed stage, counting rejected candidates, returning an undefined ratio and distinguishing *cannot determine* from *failed* are all schema and control-flow decisions; a system that makes them cannot easily lie about itself afterwards. The third is that a repair oracle needs more than tests. The re-analysis step exists because the repositories most in need of repair are precisely the ones whose tests never covered the defect, and any verification design that ignores this is verifying the test suite rather than the fix.

19.4 Concluding remarks

RepoVeriX is, finally, an argument made in software: that a tool may be permitted to be uncertain but not to be vague, and that the difference between the two is a matter of design. The system is honest about what it has established and about what it has not, and it is built so that a reviewer can check the first claim and see the second. The next steps are clear and none of them require rethinking the architecture: run the benchmark, broaden the corpus, deepen the data flow, and take the audit to the pull request where developers already are. The apparatus for measuring those improvements is already in the repository, which is the most useful thing a prototype can leave behind.

References

References are divided into the repository's own primary sources and the external works that inform the concepts used in this report. Primary sources are cited by path within the project, following the convention used throughout the document.

A Primary sources from the project repository

- RepoVeriX. *README.md* — project statement, feature list, architecture summary, research questions, limitations and future work. Repository root.
- RepoVeriX. *docs/architecture.md* — modular monolith rationale, layer and module inventory, experimental configurations, key guarantees.
- RepoVeriX. *docs/analysis-pipeline.md* — stage-by-stage pipeline description, failure handling and reproducibility metadata.
- RepoVeriX. *docs/evidence-model.md* — evidence kinds, candidate-to-finding flow, status semantics.
- RepoVeriX. *docs/verification.md* — verification workflow, outcome vocabulary, sandbox security and API surface.
- RepoVeriX. *docs/security.md* — threat model for archives, repository code, prompts, environment and resources.
- RepoVeriX. *SECURITY.md* — hardening notes covering rate limiting, input validation and operational controls.
- RepoVeriX. *docs/database.md* — entity relationship description and table-by-table column notes.
- RepoVeriX. *docs/api.md* — endpoint reference, status vocabulary and interface conventions.
- RepoVeriX. *docs/experiments.md* — research questions, benchmark framework, metric definitions and current status.
- RepoVeriX. *docs/website-audits.md* — passive crawl safety model, measured dimensions, scoring honesty and data model.
- RepoVeriX. *docs/development.md* — local setup, test commands, end-to-end demonstration script and model configuration.
- RepoVeriX. *docs/DEPLOY.md*, *docs/DEPLOYMENT_GUIDE.md*, *docs/MANUAL-SETUP.md* — deployment topology, operator checklist and environment reference.
- RepoVeriX. *backend/app/analysis/* — analysis engine modules (45 modules, 13,402 lines), including ingestion, parsing, knowledge, detectors, context, redaction, llm, evidence, validation, repair, patch operations, verification and orchestration.
- RepoVeriX. *backend/app/db/models.py* — 28 mapped tables, enumerations and relationship definitions.
- RepoVeriX. *backend/app/api/routes/* — 22 routers containing 112 route declarations.
- RepoVeriX. *backend/prompts/* — nine versioned prompt templates.
- RepoVeriX. *backend/tests/* — 51 test modules containing 544 test functions, plus seeded fixture repositories.
- RepoVeriX. *bench/configs/experiments.json*, *bench/ground_truth/*, *bench/reports/README.md* — benchmark configuration, annotated ground truth and reporting rules.
- RepoVeriX. *frontend/src/* — Next.js application (124 TypeScript modules, 22,580 lines, 40 page routes).
- RepoVeriX. *Dockerfile*, *backend/Dockerfile*, *frontend/Dockerfile*, *docker-compose*.yml, *Caddyfile*, *render.yaml*, *railway.json* — build and deployment artefacts.
- RepoVeriX. *.github/workflows/* — continuous integration, deployment and operations-cadence workflows.

- RepoVeriX. *RepoVeriX-Presentation.pptx* — project presentation deck (reviewed; the report's figures were generated from repository facts rather than from the deck).

B External and conceptual sources

The works below inform the concepts used in this report. They are cited in the text by family rather than by individual entry, because the report distinguishes approaches rather than attributing specific mechanisms to specific papers; a reader who wants the primary literature will find it by way of these pointers, and the project repository's own documentation lists the systems it was positioned against when the work began.

- OWASP Foundation. *OWASP Top Ten* — the standard reference for web application security risk categories referred to in Chapter 4.
- OWASP Foundation. *OWASP Application Security Verification Standard* — used conceptually for the authentication, session and authorisation expectations discussed in Chapters 7 and 16.
- NIST. *Secure Software Development Framework, SP 800-218* — framing for the supply-chain and dependency considerations in Chapter 18.
- OASIS. *Static Analysis Results Interchange Format (SARIF) 2.1.0* — the interchange format used for findings export.
- Chen, Z. et al. *A LLM-based approach to automated code review* and related empirical studies of model-based code review — background for the model-based review family in Chapter 4.
- RepoAudit-style repository-level code QA research — the family of systems that analyse whole repositories rather than single files, discussed in Chapter 4.3.
- CodePlan and planning-oriented repository agents — evidence that repository structure improves model reasoning, discussed in Chapter 4.3.
- Le Goues, C. et al. *Automated program repair* (survey literature) — the taxonomy of template, search-based and learning-based repair used in Chapter 4.4.
- Just, R. et al. *Defects4J* and the broader benchmark tradition in program repair — methodological precedent for the benchmark design in Chapter 13.
- Tree-sitter documentation — incremental parsing library used for the structural model in Chapter 7.5.
- Framework and platform documentation: FastAPI, SQLAlchemy and PostgreSQL for Chapters 8 and 11; Next.js for Chapter 10; Docker for the resource constraints of the sandbox in Chapter 7.12.

Appendix A — Rule and Detector Reference

This appendix consolidates the rule reference used by the detectors, the rule catalogue in the interface and the benchmark ground truth. Each rule is listed with the defects it addresses, the evidence the engine attaches, the deterministic repair that exists for it, and the fixture defects that exercise it in the benchmark.

Table 24. Rule reference, evidence and benchmark coverage

Rule	Defect class	Evidence attached	Template repair	Fixture coverage
RVX-SQLI-001	SQL injection, Python	Query assembly lines, execution sink, tainted-parameter signal, route-handler signal.	Parameterised query	Python fixture, function at line 53.
RVX-SQLI-JS-001	SQL injection, JavaScript	Template-literal assembly and client execution site.	None (model repair only)	JavaScript fixture, line 18.
RVX-SECRET-001	Hardcoded credential, primary	Assignment site, credential-shaped literal, module scope.	Environment indirection	Python fixture, line 12.
RVX-SECRET-002	Hardcoded credential, variant	Assignment site with provider-shaped prefix.	Environment indirection	Not exercised by fixtures.
RVX-SECRET-JS-001	Hardcoded secret, JavaScript	Constant assignment with secret-shaped name.	None	JavaScript fixture, line 13.
RVX-CMDI-001	Command injection, Python	Constructed command string and shell invocation.	Argument-form invocation	Python fixture, line 72.
RVX-CMDI-JS-001	Command injection, JavaScript	Interpolated command and child-process execution.	None	JavaScript fixture, line 24.
RVX-EVAL-001	Unsafe evaluation, Python	Evaluation call with caller-supplied expression.	Remove dynamic evaluation	Python fixture, line 79.
RVX-EVAL-JS-001	Unsafe evaluation, JavaScript	Evaluation or function construction from input.	None	JavaScript fixture, line 31.
RVX-CRYPTO-001	Weak hash	Hash primitive call used on token material.	Stronger hash	Python fixture, line 84.
RVX-EXCEPT-001	Broad exception swallowing	Handler that discards the error.	Not templated	Python fixture, line 94.

Source: Project repository — backend/app/analysis/detectors.py, frontend/src/lib/rules.ts, bench/ground_truth.

The pattern in the last two columns is deliberate and worth explaining. Templates exist for the five strong rule families, where the insecure form and its correct replacement are structurally unambiguous. The JavaScript rules and the exception rule have no template, so a repair for them, if any, comes from the model and must survive verification like any other patch. The benchmark fixtures exercise nine of the eleven identifiers, which means two rules are shipped, documented and unit-tested but are not currently measured by the benchmark — a gap worth closing when the corpus is broadened.

Appendix B — Configuration and Environment Reference

The following table groups the environment variables that an operator is most likely to touch, with the behaviour each controls. It is a summary of the repository's configuration module and its environment template rather than a complete transcription; the template in the repository is authoritative and lists every variable with a comment.

Table 25. Operationally significant configuration groups

Group	Representative variables	Operational significance
Application	Environment name, API prefix, debug flag, allowed hosts, CORS origins, documentation exposure.	Determines what the service reveals and which clients may call it; documentation exposure is disabled by default in production.
Database	Connection URL, automatic table creation flag.	Switches between PostgreSQL and SQLite; automatic creation is intended for development and tests.
Storage	Repository storage directory, artifact storage backend, S3-compatible credentials and endpoint.	The S3 adapter fails closed when credentials are missing, which prevents a multi-instance deployment from silently writing to local disk.
Ingestion limits	Maximum repository size, file size, file count, symbol count, log characters, clone timeout.	Bounds the resource an untrusted repository can consume.
Sandbox	CPU limit, memory limit, timeout, network mode, process cap.	The isolation contract for executing untrusted project code.
Model access	Provider, model identifier, per-provider keys and base URLs, fallback order, temperature, timeout, retries, candidate cap, context cap.	Controls cost and availability of the reasoning stage; absent keys degrade the stage rather than the scan.
Authentication	JWT secret and algorithm, token lifetime, verification requirement, disposable-address policy, lockout and backoff settings.	The account-security posture; the secret must be generated per deployment.
Rate limiting	Global enable flag, public, user and action budgets, authentication attempts and window, backoff floor and ceiling, proxy-header trust.	Abuse resistance; proxy-header trust must only be enabled behind a reverse proxy that overwrites the header.
Email	Backend selection, SMTP parameters, sender identity, resend and reset hourly caps.	Determines whether verification and reset mail is delivered or written to the log.
Billing	Enforcement flag, provider keys, product identifiers, environment, demo mode, operator addresses.	Plan gates and operator privileges; demo mode exists for evaluation without a payment provider.
Website audits	Crawl limits, quota, request timeout, response size cap.	Bounds the politeness and cost of a passive crawl.
Observability	Log level, metrics exposure, alerting endpoints.	Operational visibility described in Chapter 17.

Source: Project repository — backend/app/core/config.py, .env.example, .env.prod.example.

Appendix C — Module, Requirement and Test Matrix

This appendix is the traceability artefact promised in Chapter 6, expanded to module level. It allows a reader to move from a requirement to the module that satisfies it and to the test area that defends it.

Table 26. Traceability from requirement to module and test area

Requirement	Primary modules	Supporting modules	Test area
FR-01, NFR-07	auth routes, account security routes, security core	account security service, auth audit, rate limiter	Authentication, account security routes, admin access
FR-02, NFR-01	ingest, discovery	core ssrf (for URL ingestion), process utilities	Ingestion, security, hardening
FR-03, FR-04, NFR-06	scans routes, orchestrate, runtime	recovery, metrics, logging	Scans, orchestrator, recovery
FR-05	parsing	knowledge	Parsing, intelligence
FR-06, FR-07	detectors, knowledge, tools	archsmells, attack paths, dependency reachability	Detectors, architecture-smell evidence, tier workflows
FR-08, FR-09, NFR-03, NFR-04	context, redaction, llm	core crypto, middleware	Model providers, security regression
FR-10, NFR-06	evidence, validation, counterexamples	regression, risk model, rule selection	Validation, detectors, tier workflows
FR-11, FR-15	findings routes, reporting, sarif	impact, finding chat, feedback	Findings, reporting, SARIF export
FR-12, FR-13	repair, patchops, patchquality	prooffix, test generation	Patches, proof-of-fix
FR-14, NFR-02	verify, patchops	process utilities, proof-of-fix	Verification, production lifecycle
FR-16, NFR-03	sharing service and routes, feedback routes	reporting	Feedback and sharing
FR-17, NFR-08	webcrawler, webanalyze, webrun, website routes	core ssrf, rate limiter	Websites and crawl safety
FR-18	organisations routes, access service	models, dependencies	Team features, admin access
FR-19, NFR-03	tokens routes, models	authentication dependencies	Team features, security
FR-20	benchmark package	orchestrate	Benchmark
FR-21	billing service and routes, dodo client	entitlements	Billing, billing persistence, entitlements
NFR-09, NFR-10	orchestrate, runtime, recovery	all analysis modules	Orchestrator, recovery, hardening
NFR-11	configuration module	database session, mailer, mock provider	Development setup exercised by the whole suite
NFR-12	health endpoint, metrics, observability middleware	operator scripts, cadence workflow	Production operations, operational cadence

Source: Project repository — module inventory, requirements derived in Chapter 6, test modules.

Appendix D — Evidence, Reproduction and Figure Provenance

D.1 Figure provenance

The report contains no product screenshots and no stock imagery. Every figure is a conceptual diagram generated for this report from facts verified in the repository: the documented stage order, the module inventory, the route counts, the table definitions, the deployment manifests and the test inventory. The generator, its inputs and the counts it produced are retained with the report so that a reader can regenerate any figure and compare it with the diagram printed here.

Table 27. Figure provenance: what each diagram is based on

Figure	Diagram	Verified inputs
1	Layered architecture	Architecture document, API route inventory, frontend route tree.
2	Scan pipeline	Pipeline document and orchestrator module stage sequence.
3	Evidence chain and adjudication	Evidence model document and evidence module status rules.
4	Four configurations	Architecture document configuration table.
5	Verification workflow	Verification document and verification module step sequence.
6	Entity relationships	Database document and model definitions.
7	Untrusted domain and controls	Security document threat and control sections.
8	Execution isolation	Verification document and compose files.
9	Benchmark harness	Experiment document, configuration file and README reporting rules.
10	Route distribution	Counted route decorators per router module.
11	Module size distribution	Counted lines per analysis module.
12	Interface route map	Frontend route tree.
13	Deployment topology	Deployment guide, compose files and hosting manifests.
14	Test inventory	Counted test functions per area.
15	Repair decision path	Repair module template rules and generation order.

Source: author's figure generator and the repository files named in each row.

D.2 Reproduction checklist

A supervisor or examiner who wishes to verify the claims in this report can follow the sequence below. Each step names the observable outcome that confirms the corresponding claim; nothing in the list requires writing code.

1. Install the backend from its packaging metadata into a virtual environment and confirm the installed version resolves. This confirms the dependency list quoted in

Chapter 11.

2. Start the API with an SQLite connection string and open the health endpoint. This confirms the portability claim in Chapter 6 and the liveness surface in Chapter 9.
3. Open the generated documentation surface and count the routers. This confirms the twenty-two-router, one-hundred-and-twelve-declaration inventory in Chapter 9.
4. Start the frontend from the lockfile and visit the workspace routes. This confirms the route map in Chapter 10.
5. Upload the seeded Python fixture as an archive and start a scan in the static configuration. This confirms ingestion, parsing, detection and adjudication without any provider dependency.
6. Inspect a produced finding and read its evidence chain. This confirms the evidence model in Chapter 7.9.
7. Request a fix for a templated rule, then request verification with a container runtime available. This confirms the repair and verification workflow in Chapters 7.10 and 7.11.
8. Register a website whose hostname resolves to a private address and observe the refusal. This confirms the SSRF control in Chapter 7.13.
9. Run the benchmark command with a provider key configured and compare the generated summary with the pending table in Chapter 14. This is the step that converts TBD into measured values.
10. Run the test suite with the documented command and record the count. This converts the statement in Chapter 12 from a count of declarations to a count of passing tests.

D.3 Known gaps in this report

For completeness, the following items could not be established from the repository during this documentation pass and are recorded here so that no reader is left to discover them independently. The test suite was not executed, so no pass count or coverage figure is reported. The benchmark matrix was not executed, so every metric cell is TBD. The application was not run, so no screenshot exists and none was fabricated. The deployment topologies are documented in the repository but were not exercised here. The billing and email integrations depend on external providers that were not configured. And the historical dataset or user-study evidence that would support adoption claims does not

exist in the repository and is therefore not claimed.

Each of these gaps is closed by a step in the reproduction checklist above, and each corresponds to a claim this report deliberately did not make. The report is longer for that discipline rather than shorter, because explaining what a system establishes — and how a reader may confirm it — is the substance of technical documentation, not a preface to it.

End of report

SUMIT AGGARWAL

Roll Number 04317702723 · Section CSE-A